

What It Takes to Trust a Measurement: Instrument Failures in an LLM Malware-Analysis Pipeline

Abstract

Multi-agent LLM pipelines map malware evidence to MITRE ATT&CK techniques, and their components are rarely measured against the deterministic tooling they are built on. This study evaluates one such pipeline and reports both its measurements and the failures of the instrument that produced them. A no-LLM baseline, the sandbox’s own signature mapping, reaches F1 0.1526 [+0.1114, +0.1998] on 97 samples. On the 13 of those where both arms ran, scored per sample against the same ground truth by the same code, the full pipeline reaches 0.1160 against that baseline’s 0.1130, paired +0.0030 [−0.0353, +0.0344], at a resolution of 0.085. On 24 real samples, one per family, negotiated multi-agent consensus beats a single judge by +0.0537 F1 [+0.0362, +0.0714], and so does a stochastic-noise control, by +0.0532; the two differ by +0.0005 at a resolution of 0.046, so what helps is the calls the arms share, not the negotiation. Verbal confidence, which every deterministic gate consumes, ranks correct claims above incorrect ones at AUC 0.550, on an interval containing chance. Seven defects in our own instrument produced plausible results rather than errors and 2,744 passing tests caught none: four crossed a boundary with another server, and three share a different shape, a measurement’s cause assigned rather than measured. The largest is this paper’s own statistics, every interval having resampled rows when the observations were clustered, whose correction widened the anchor interval 2.32-fold and turned two equivalence claims into bounds.

Keywords: LLM agents, malware analysis, MITRE ATT&CK, evaluation methodology, clustered inference, negative results

1. Introduction

Mapping malware evidence to MITRE ATT&CK technique identifiers is a labelling task that large language models are now routinely applied to, and the systems that perform it are rarely a model alone. A working pipeline wraps the model in deterministic tooling: a sandbox that detonates the sample, a disassembler that recovers its structure, retrieval indices that supply prior cases, and rule engines that assert techniques directly from signatures. The model’s contribution is therefore a difference against that tooling rather than a score in isolation. That difference is almost never reported. Büchel et al.’s systematisation re-evaluates more than forty technique-extraction systems in one setting and finds them “largely incomparable”,

because each uses its own ontology and its own inaccessible dataset [1]. An F1 value read against no baseline refers to nothing, and the baseline that matters for an LLM pipeline is the deterministic engine it was built on top of.

A second barrier is that such a pipeline is itself a distributed system, and its evaluation inherits every property of one. Ours calls a reverse-engineering server for disassembly, a sandbox for detonation, a vector store for retrieval and a model server for inference, over three protocols. Each of those boundaries is a place where a request can succeed and still not mean what the caller assumed, and the resulting error is not visible as an error. Silent failure of this kind is a long-established class in production software [2, 3, 4], and it is now being catalogued for LLM orchestration frameworks and inference engines as well [5, 6]. What changes in an evaluation setting is the artefact. The product of a silent failure is not a degraded user session that someone reports; it is a measurement that is wrong, looks right, and is written down.

This work reports the evaluation of one such pipeline, built for ATT&CK mapping over static, dynamic and network evidence, and the failures of the instrument that produced that evaluation. The system fuses six deterministic evidence layers, three domain analysts running as ReAct loops over tool interfaces, an LLM judge, a weighted corroboration cascade, two retrieval tiers and deterministic confidence gating. It was built around four architectural claims: that multi-agent consensus over heterogeneous evidence channels beats a single reader, that a multi-layer corroboration cascade improves evidence quality, that two-tier attribution supplies useful priors, and that falsification before confidence disciplines unsupported claims. Each claim was measured at an equal total token budget against a simpler alternative, with a stochastic-noise control, with the firing rate of each mechanism measured before its effect, and with intervals resampled at the level the observations are independent at.

All four claims returned a negative or a near-null result, and the study that established this was itself wrong several times over. Seven defects in the instrument produced plausible results rather than errors, and a suite of 2,744 passing tests caught none of them. Four crossed a boundary with another server: an optional argument the agent never supplied arrived as an explicit null and disabled every tool on one interface; a program reported as loaded never became the one under analysis; a refused load returned HTTP 200 with an error in the body; and two independently correct bounds composed into a path that returned nothing. The other three crossed no boundary at all and are described in Section 1.2. The largest of the seven is this paper’s own statistics: every interval in an earlier draft resampled rows when the observations were clustered, and correcting that widened the anchor interval 2.32-fold and turned two claims of equivalence into bounds.

The price of those defects is reported rather than hypothesised. One completed 210-sample temporal-drift study is withdrawn from this paper because it met the precondition for one of the defects and its per-sample outputs had not been retained, so whether it was affected can no longer be established. Four arms of a later ablation are unattributable for the same reason one level up, the environment a measurement

ran in having gone unrecorded where the measurement itself was kept.

The remainder of the paper is organised as follows. Section 1.1 places the work in the technique-extraction, agentic-analysis and evaluation-methodology literature and states the contributions. Section 2 describes the pipeline, the corpora, the serving configuration and the measurement design. Section 3 reports the measurements, the seven instrument failures, the detector that found most of them, and the limitations. Section 4 concludes.

1.1. Related work

Language models are already applied across the malware task surface, tracking malicious packages in a registry [7], detecting Android malware from application features [8] and from generated training samples [9], and summarising what a sample does in prose [10]. None produces ATT&CK technique identifiers from a running analysis of a Windows binary, which is the task this pipeline attempts. Automated technique extraction has moved from supervised classifiers such as TRAM [11], rcATT [12] and TTPDrill [13], through neural extractors such as EXTRACTOR [14], AttacKG [15] and LADDER [16], to retrieval-augmented generation. TechniqueRAG [17] pairs off-the-shelf retrievers with an instruction-tuned re-ranker and fine-tunes only the generator, motivated by data scarcity: ATT&CK defines over 550 sub-techniques while roughly 10,000 annotated examples exist publicly. A separate group’s hierarchical successor injects the tactic-to-technique taxonomy as an inductive bias and cuts the candidate space by 77.5% [18] [preprint], and TTPrint [19] [preprint] keeps only candidates supported by both a localised evidence span and the MITRE definition. Neither result is restated here as a comparator, both being unreviewed and self-reported against baselines that Büchel et al.’s systematisation calls “largely incomparable” [1]; that survey re-evaluates more than forty systems in a unified setting, reports a ceiling existing approaches have not crossed, and finds that traditional NLP approaches outperform embedder-based and generative ones in realistic settings.

Our describe-then-map design removes technique-ID recall from the model entirely: the analyst describes behaviour and a deterministic index assigns the identifier, which is a domain instantiation of Infer-Retrieve-Rank [20] [preprint] and is stricter than [17], where the model still ranks among retrieved candidates. What we add is a decomposition of the systematisation’s insight. It reports that embedders lose; we measure where, on TRAM2 [11] at N=4,913 and on the independently annotated AnnoCTR corpus [21]. Ranking quality and gate quality behave as separable axes: dense embeddings rank better while their scores barely separate a correct pick from a wrong one, a lexical index ranks worse while gating cleanly, and composing the per-axis winners beats either pure backend. The separability itself is not ours, Abdallah et al. [22] treating retrieval confidence as a dimension distinct from effectiveness and finding calibration “consistently weak across model families”; what remains ours is the inversion, that here the lexical backend is the better gate while the semantic one is the better ranker. Two further results have prior art

we cite rather than compete with. Auto-correcting valid but weakly-aligned identifiers damages 38% of already-correct labels to recover 21% of wrong ones, and that asymmetry is not a discovery, since grammatical error correction evaluates with F0.5 precisely because a false correction costs more than a missed one [23, 24]; our contribution is the mechanism, that correct-but-weak and wrong-but-valid identifiers are not separable by an alignment score, so the shipped policy is restricted to the invalid-to-valid case where zero regression holds by construction. Separately, asked for an identifier it does not know, the model enters a degenerate loop, and neural text degeneration has competing established accounts locating the cause in the likelihood objective and in training-data repetition respectively [25, 26]; what we add is the engine-level consequence, that the server honours `repeat_penalty` while silently ignoring three sibling parameters, which converts a tight loop into a slower enumeration and exhausts a budget inside an operational deadline.

Agentic systems now drive reverse-engineering backends through tool interfaces, and the model tier splits sharply by role: fine-tuned binary specialists are small and open-weight, among them ReCopilot [27] [preprint], LLM4Decompile [28] and Nova [29], while tool-driving agents use frontier models. TTPDetect [30] [preprint] is the closest system to ours, identifying TTPs in stripped malware binaries through retrieval-narrowed entry points and a function-level agent, reporting 93.25% precision and 93.81% recall at function level and 87.37% precision on real-world malware. We do not claim binary evidence as an input modality; that ground is theirs. The one gap we occupy is tool-catalogue scale. Degradation of tool selection as a catalogue grows is documented generally, with LongFuncEval reporting a 7 to 85% performance drop as tool count increases [31] [preprint] and a cut from 46 to 19 tools saving up to 70% of execution time on an edge model [32], but not for a reverse-engineering catalogue whose schemas are large and whose tools semantically overlap. That exposing roughly 201 tools, about 22k tokens of schema, is infeasible at this model scale is the domain instance, and it is a single feasibility point rather than a degradation curve.

Multi-agent debate is a standard pattern, including in security, where PhishDebate [33] assigns four specialised agents to distinct views of a webpage and reports 98.2% recall. Two recent results change how such claims must be read. Holding the reasoning token budget constant, Tran and Kiela find single agents consistently match or beat multi-agent systems on multi-hop reasoning, with an information-theoretic argument from the Data Processing Inequality and a crossover appearing only at degradation 0.7 [34] [preprint]. Bertalaníć and Fortuna [35] reach the same conclusion on 7B and 8B open-weight models, where debate consumed 2.1 to 3.4× more tokens for equal or lower accuracy, and name three failure modes: sycophantic conformity, contextual fragility, and consensus collapse discarding correct answers already in the pool. Both papers scope their negatives to homogeneous agents decomposing a single context, and both name degraded or noisy context as the exception, which is the regime a 600-import binary plus a sandbox report plus a network capture occupies. Whether heterogeneous evidence-channel decomposition survives the control that homogeneous debate fails is the question our equal-budget

ablation asks. Our contribution here is a failure mode adjacent to sycophantic conformity: an analyst whose evidence channel was empty paraphrased its peers, and because the echo returned tagged with that analyst’s own domain, the corroboration counter read it as independent confirmation and promoted a single-source finding. In a security pipeline the harm is not a wrong answer but a fabricated independent confirmation. Weighting evidence by source reliability and discounting non-independent sources is Dempster-Shafer theory, decades old, and our cascade is an instance of it with hand-chosen constants, which we treat as a limitation. Measuring five perturbations of those constants, including inverting the most- and least-trusted layers, changed the top-10 ranking on 10.6 to 27.5% of samples and the corroborated set on none, because the corroboration decision is a function of layer count alone.

Confidentiality-driven local deployment is established rather than novel. REx86 [36] fine-tunes eight open-weight models for x86 reverse engineering explicitly because “cloud-hosted, closed-weight models pose privacy and security risks and cannot be used in closed-network facilities”, validating with a 43-participant user study, and the capability gap is quantified elsewhere at 4 to 7 months behind the closed frontier at roughly 45× lower cost per task. We inherit that constraint and cite it. Our deployment contribution is narrower and practitioner-facing: on a hybrid-offload MoE the KV cache costs about 10.85 KiB/token and context length barely moves system RAM because the cost is the offloaded weights, a closed-form estimate over-predicted KV by roughly 4× and was overturned by measurement, and speculative decoding gave no throughput gain on this architecture.

This work’s methodological results belong to an established critique tradition. Arp et al.’s *Dos and Don’ts* identified ten pitfalls in ML-for-security, and *Chasing Shadows* [37] is its direct successor, surveying all 72 peer-reviewed LLM-security papers of 2023 and 2024 and finding every one exposed to at least one of nine pitfalls with only 15.7% explicitly discussed. Our instrument-validity finding, that a single-run parsed-claim count produced contradictory rankings of the same arms across decoding budgets, is a worked example inside that category rather than a new observation. Two evaluation results appear to be unoccupied. The first is a case-prior retriever that is genuinely good in its own vocabulary and scores below a label-frequency prior when queried the way production queries it, because query and corpus share only their boilerplate; dense retrieval being the standard remedy for vocabulary mismatch makes this a failure of the remedy, visible only in the score distribution while top-k accuracy stayed healthy. A published negative RAG result in malware analysis exists by a different mechanism, retrieved context diluting a signal-extraction task [38]; comparison against a trivial label-only baseline is long established [39]; and a systematic review by the same group found a considerable share of published multi-label results to be no better than that baseline [40] [preprint]. The second is an advisory prompt hint whose measurable effect was completion under an operational time budget rather than mapping accuracy, and we found no work measuring generation completion as a channel through which prompt changes act. On temporal stability the axis matters more than the result: per-

formance falls as evaluation moves away from the training period and scale does not close the gap [41], but that work varies the distance between training and test time while ours fixes the model and varies the era of the input binary. We no longer have a result on that axis, for the reason given in Section 3.9.

The paper’s methodological spine belongs to an area that already exists, and locating it there matters more than claiming it. Gunawi et al. [2] measured where an error signal is lost, finding that 13% of propagation channels drop an error code without handling it and that calls between modules are a major cause. Yuan et al. [3] ruled that a handler which only logs is a handler that ignores, and attributed 25% of catastrophic failures to errors that were explicitly signalled and then ignored. Alquraan et al. [4] found the majority of network-partition failures in cloud systems to be silent, with every warning the rest produced “confusing, with no clear mechanism for resolution”. Our boundary defects sit inside that description without strain, and the LLM-specific instance of the same shape is now being catalogued too, in bug taxonomies for agent orchestration frameworks [5] and for inference engines [6], the latter carrying both incorrect request parsing as a root cause and silent error as a symptom; silently overruling a requested parameter back to a default is itself a named misconfiguration failure mode with a measured prevalence [42]. Adjacent work reaches the same place from the interface side: mining defects in MCP reference servers, Oyelayo et al. [43] find data validation and type issues to be the second most prevalent class at 13.97%, the bucket our null-for-unset-optional defect falls into, and input dependencies that a machine-readable specification cannot express are “the norm, rather than the exception, with 85% of the reviewed APIs” carrying them [44]. The detector is not new either: “distinct inputs should produce distinct outputs” is an ordinary metamorphic relation, and metamorphic testing exists precisely for programs whose correct output is unknown [45]; stress-testing an LLM judge’s consistency under input variation is likewise established [46]. The newest of our mechanisms is a domain instance rather than a discovery. Building a parameter-size series, we produced a rank correlation of +0.866 between model size and F1, reproducing the $\rho=0.85$ at $p=0.014$ that the nearest prior work reports [47] [preprint], from an axis on which the low-scoring row was a model disabled by a configuration flag rather than limited by its size. That phenomenon is established: under strict output-length constraints performance “might not scale monotonically with the model size” [48], across 6.5M instances inference-time configuration moves performance “both absolute and relative” [49], extra test-time compute lets a smaller model overtake a much larger one [50, 51], and lengthening reasoning steps improves accuracy [52]. What we would add sits in the remedy rather than the phenomenon: their protocol is adapted per model, ours has to be verified per arm, because one of our providers accepts the parameter that would match two arms and does not act on it. The same is true one layer down, where OpenAI-compatible servers disagree about which token-limit parameter they honour, documented in their own issue trackers as `llama.cpp` #8634 [53] [preprint] and `vLLM` #11976 [54] [preprint].

Every result of ours cited above was produced on one model on one machine,

Qwen3.6-35B-A3B at IQ3_K_R4 quantisation served by `ik_llama.cpp` on a single RTX 5060 host with 31 GiB of RAM. Where a statement concerns retrieval or the deterministic cascade rather than generation, no model was involved and the binding limit is the index and the corpus instead. We state this here because the surrogate fallacy is the pitfall this work is most exposed to, and because parameter size was the only statistically significant predictor of F1 in the nearest external study [47] [preprint], which makes single-model findings exactly the kind that should not be read as properties of an architecture. Where a result is a negative obtained under a configuration favourable to the alternative, it travels further than a positive, and we say which is which at each claim.

1.2. Motivation and contributions

Two observations motivated the work reported here. First, the components of an LLM analysis pipeline are ordinarily justified by the mechanism they implement rather than by a measurement, and a mechanism that is sound in isolation can contribute nothing once wired to real inputs; establishing which of the two holds requires an equal-budget comparison against a simpler alternative and a baseline that contains no language model at all. Second, such a comparison is only as trustworthy as the instrument that produces it, and in a pipeline assembled from several servers the instrument fails in a way that does not announce itself. Both observations were reached the expensive way, after four architectural claims returned nulls and seven measurements turned out to have been wrong.

The contributions are therefore organised around the evaluation rather than around the architecture, and each is a measurement or a mechanism rather than a proposal.

(i) *A no-LLM baseline for ATT&CK mapping, and the pipeline scored against it.* The sandbox the pipeline is built on maps its own signature hits to technique identifiers deterministically, and scored per sample against family-level MITRE ground truth it reaches F1 0.1526 [+0.1114, +0.1998] on 97 samples. On the samples where both arms ran, the full pipeline is +0.0030 F1 above it [−0.0353, +0.0344], at a resolution of 0.085. This is the comparison without which every F1 in this literature, including our own earlier ones, refers to nothing.

(ii) *Four architectural negatives, each reported with the resolution of the design that produced it.* Multi-agent consensus at equal token budget, a weighted corroboration cascade, two-tier attribution and a deterministic confidence gate were each measured, and each returned a negative or a near-null result. A null without its minimum detectable effect is unreadable, so every one is stated with the effect its design could have detected at 80% power. Where a corpus large enough to separate the arms was available, the finding is sharper than a null: on 24 real samples the decomposition into several calls is worth +0.0537 F1 over a single judge, a stochastic-noise control is worth +0.0532, and the two differ by +0.0005 at a resolution of 0.046. What helps is the calls the arms share, not the negotiation between them.

(iii) *Seven instrument failures, with the layer each occurred at and what actually found it.* Each produced a plausible result rather than an error, and 2,744 passing tests caught none. Four crossed a boundary with another server and fall inside a described class of silent failure; three crossed no boundary at all and share a different shape, in which a measurement’s cause was assigned rather than measured. We report the price alongside the mechanisms: one completed study withdrawn, and four arms of a later ablation unattributable.

(iv) *An output-cardinality check, reported beside every batch result rather than written as a test.* Counting how many distinct outputs N inputs produced found every one of the boundary failures, needs no ground truth and no oracle, and costs one line. It works only on a batch, which is why it belongs in a results table and not in a unit suite.

(v) *An arm-selection rule keyed on measured rather than requested configuration.* One provider accepts the parameter that would match two arms and does not act on it, so an arm can be labelled matched while running the opposite configuration. On the two models where the flag can be set it is worth 0.34 to 0.45 F1, the only effect in this paper that exceeds its own design’s minimum detectable effect, and larger than any architecture or parameter count we measured.

2. Materials and methods

2.1. Scope and assumptions

This study evaluates one pipeline that maps evidence about a Windows PE malware sample to MITRE ATT&CK technique identifiers and emits a STIX bundle. The scope is deliberately narrow in four respects, and every result should be read inside it. The model is a single local mixture-of-experts deployment, quantised, on one host; the comparison endpoints are three commercially hosted inference services. Ground truth is family-level MITRE uses, resolved to a sample through its family signature, which is coarse and carries a structural recall ceiling. Only Windows PE is analysed dynamically, because the sandbox instance has one analysis machine and no Linux guest. And the contribution claimed is the evaluation rather than the architecture: the system is the object under study, not the result.

Two design choices are stated here because they are not what failed. Tool exposure is not tool availability. The reverse-engineering server advertises ~165 tools, exposing the full catalogue to a model with roughly 3B active parameters is infeasible because tool selection degrades before the context does, and the static analyst is therefore given a curated 20, with high-value tools invoked deterministically from code. And the pipeline degrades rather than fails when a service is absent, so with the sandbox unreachable the dynamic path is skipped and the run completes on static evidence, a behaviour pinned by a test. That mattered during the study, because the sandbox was reachable from one network only and every static-only result reported here was produced by that degradation working as designed.

2.2. The pipeline under evaluation

Six deterministic evidence layers assert techniques directly from signatures, rules and artefacts. Three analysts then run as ReAct loops over heterogeneous evidence channels, a judge synthesises a verdict and emits the bundle, and a deterministic layer adjudicates between them. Table 1 lists each component with what it was measured to contribute.

Table 1: The pipeline’s components and what each contributes, as built and as measured.

component	what it does	measured contribution
static analyst	ReAct loop over a headless reverse-engineering server, 20 tools from a curated allowlist	operational; its salvage path was defective
dynamic analyst	ReAct loop over a CAPEv2 sandbox via MCP	operational; Windows PE only on our instance
network analyst	local PCAP analysis over the sandbox’s capture	operational; two-thirds of its domains are the analysis VM describing itself
judge	synthesises a verdict and emits STIX	contributes no technique the cascade did not already hold
corroboration cascade	weights layers, marks a technique corroborated at ≥ 2 contributing layers	never reaches the artefact (0/32)
reconciliation step	drops unresolvable attack-patterns, restores every cascade technique the judge omitted	makes the cascade’s set a subset of every emitted bundle
confidence gating	caps confidence for unsupported obfuscation and injection claims	fires on 0.82% of techniques
case-prior RAG	retrieves similar past cases to prime mapping	loses to a label-frequency prior in production
family-feature RAG	retrieves family fingerprints	+0.0029 F1 end to end
opcode-hash attribution	normalised function hashes matched against a corpus	fires on 0 of 18 samples
sink-reachability hint	ranks functions reachable to sensitive APIs, injected as prompt steering	fires on 56.7%; Δ techniqueIDs +0.50 [−3.33, +4.50]

All four architectural claims listed in Section 1 are measured in Section 3 and every one is negative or near-null. The components are not broken and three of them work well in isolation; they do not move the end-to-end result.

2.3. Samples, ground truth and the sandbox

The dynamic cohort is n=100 Windows PE samples from MalwareBazaar, stratified by year at seed 20260810 with its digest recorded, of which 97 produced a

usable sandbox report. Ground truth resolves a MalwareBazaar family signature to an in-repo MITRE uses fixture through an explicit alias map with a CamelCase-split fallback. It is family-level and uncurated at technique level, so a single binary of a family need not exhibit all the techniques catalogued for that family and absolute recall carries a structural ceiling. Absolute F1 values here are therefore not comparable to work using per-sample expert labels; the bias is approximately constant across arms, which makes within-study contrasts the defensible reading and is exactly why a baseline matters. The withdrawn temporal-drift study’s manifest survives as 210 dated samples over 7 cohorts and 27 families, metadata only, so that cohort can be reconstructed even though its results cannot.

Three properties of the sandbox bound what can be reproduced. It is CAPE 2.5 at a private address with one analysis machine and no Linux guest, so an ELF submitted there joins the 10,348 tasks that are never scheduled. Reports are retained for days rather than indefinitely: sampled across the full task-id range, 18 of 18 older tasks return "Reports directory does not exist", so the local archive of fetched reports is the only copy and re-submitting the same samples is not a reproduction recipe on its own. And the instance rate-limits with a throttle response byte-identical to its auth refusal, {"error": true, "message": ""} in both cases, so a harness reading that string as a capability verdict will mis-classify a throttle as a missing permission, as ours did briefly. A new Windows submission is scheduled in ~1 second and completes in ~5.5 minutes, which puts an n=100 cohort at roughly 9 hours of sandbox time.

2.4. Models, endpoints and serving configuration

Table 2 pins the local model and engine. Naming the imatrix calibration dataset matters, because two IQ3 quantisations of the same model calibrated differently are not the same artefact, and most papers reporting a quantisation level cannot say which calibration produced it.

Table 2: The local model and inference engine, pinned by digest and commit.

model	Qwen/Qwen3.6-35B-A3B, quantised IQ3_K_R4 by Unsloth
GGUF sha256	d0de70ef...c4ea, computed locally and matching the HuggingFace etag
HF revision	cfd350fd...1f0d, retrieved 2026-05-11
imatrix calibration	unsloth_calibration_Qwen3.6-35B-A3B.txt, 510 entries over 76 chunks
architecture	hybrid recurrent (SSM keys + full_attention_interval=4), from the GGUF metadata
engine	ik_llama.cpp at eb570eb96689c235933b813693ca28ab9d3d26de (#1778)
host	one RTX 5060, 31 GiB RAM, 16 threads

The engine commit was reconstructed rather than recorded, and we say so rather than presenting the identifier as though it had been captured at build time: llama-

`server --version` prints `version: 0 (unknown)` on a build tree that was never a git checkout, so the commit was recovered from a depth-1 clone vendored elsewhere in the project and proved against an identical 837-file source list with exactly one file differing once line endings are normalised. The server is launched as

```
llama-server -m Qwen3.6-35B-A3B-IQ3_K_R4.gguf \
-c 131072 -t 16 -fa on -ctk q8_0 -ctv q8_0 -ngl 999 \
-ot "blk\.[0-9]\.ffn_(up|gate|down)_exps=CPU" \
--context-shift on --jinja --host 0.0.0.0 --port 8080
```

serving 131,072 of the model’s native 262,144, with 30 blocks on CPU. Four measured properties of that host bound what can be reproduced on it. `llama-server` grows with cumulative requests and does not plateau, from 10.4 GB fresh to 14.8 GB after a single analyst pass and 18.1 GB after 60 minutes of multi-arm load; the growth is anonymous and unreclaimable, so long paired runs restart the server between arms, which changes no decoding parameter and is therefore measurement-neutral. Serving at 64k instead of 131k does not lower the peak, at 14.6 against 14.8 GB, because the baseline is CPU-resident expert weights. Generation varies from 162 to 20 tokens/s across requests, because on this hybrid recurrent architecture the engine writes and erases a 63 MiB recurrent-state checkpoint every few hundred tokens at ~39k tokens of context, so long-context calls fall off a cliff rather than slowing in proportion. And the disassembly container is capped at 6 GB, its JVM -Xmx4g bounding the heap only, with measured RSS reaching 5.15 GB against that nominal 4 GB cap. The working set does not fit alongside an interactive session, which is a reproducibility fact rather than an operational one, and arms measured under memory pressure are not commensurable with arms that were not.

Table 3: The inference endpoints each arm ran against, with the configuration measured rather than the configuration requested.

arm	endpoint	model	reasoning	n
local	<code>ik_llama.cpp</code> , this host	Qwen3.6-35B-A3B (IQ3_K_R4)	off	25
baseline	OpenRouter	nvidia/nemotron-3- super-120b-a12b:fr ee	on, not controllable	25 ×2
same weights, hosted	DashScope	qwen3.6-35b-a3b	off	25
same weights, hosted	DashScope	qwen3.6-35b-a3b	on	25
larger, hosted	DashScope	qwen3.6-plus	off / on	25 each

Table 3 lists the endpoints each arm ran against, and one parameter on it decides more than the model names do. `enable_thinking` is honoured on DashScope and ignored on OpenRouter, not rejected but accepted, recorded in the result file, and

not acted on: the re-run requesting it returned a 56.2% reasoning share against 56.5% without it, while on DashScope the same request produces 0.0%. The flag is worth 0.34 to 0.45 F1 on the two models where it can be set, so an arm can be labelled matched while running the opposite configuration, and arm selection therefore keys on the measured reasoning share of a completed arm rather than on the flag requested. Two further serving details are load-bearing for anyone reproducing an arm. The local server's output cap must be sent twice, because ChatOpenAI(max_tokens=N) reaches the wire as max_completion_tokens, which ik_llama.cpp does not read, so the cap must also travel in extra_body as max_tokens and n_predict; measured on this host, 48 requested yields 2805 generated with the renamed field alone and 48 with both. And that server truncates silently, returning finish_reason: "stop" at the cap and never "length", so telemetry detecting truncation by finish reason reports zero however often the cap binds; compare the generated-token count against the cap requested instead. The frontier arm ran on a free tier allowing 50 requests per day at 20 per minute. The first attempt exhausted the daily quota mid-flight, 9 calls landing and 16 returning HTTP 429, and the estimate it produced was not merely imprecise but pointed the wrong way. The quota governs what a cohort-scale frontier arm costs in wall-clock rather than in money: one call per sample over a 97-sample cohort is two days at that rate, and a full-pipeline arm at roughly 20 model requests per analysis is not reachable on that tier at all.

2.5. Experimental design

Four terms are used in one sense throughout. An *arm* is one condition of one experiment, a configuration under which every input is scored, so that two arms differ in the one thing being tested. A *sample* is a real malware binary from the dated cohort, scored against its family's MITRE uses set. A *fixture* is one of the five synthesised inputs used by the equal-budget arms, whose evidence is generated from its own technique list and which therefore has a ceiling a real sample does not; samples and fixtures are different populations with different ground truth, they are never pooled, and where both appear in one figure they appear on separate axes. The *reconciliation step* is the deterministic pass that compares the judge's bundle against the corroboration cascade's set and restores what the judge omitted.

Arms are compared at an equal total token budget: a multi-agent arm making N calls receives B/N per call against a single arm's one call of B , so a win cannot come from spending more. The design follows Bertalaníč and Fortuna [35], including a stochastic-noise control in which one analyst receives evidence irrelevant to the sample. That control establishes that the harness can detect a difference at all: in the fixture consensus study the noise arm separated (0.3366 against 0.3975 and 0.4136) while the treatment did not, which distinguishes no effect from no sensitivity. For reasoning models the budget must cover reasoning, because our frontier endpoint spent 56.5% of its output on reasoning across 25 real prompts and 84% on a one-token answer, so capping content alone would have granted it roughly twice the generation for the same nominal budget. Arms must also sit on the same side of the reasoning switch. Measured on two models at 25 calls each, enabling the flag

moved F1 by 0.45 on one and 0.34 on the other, in both cases because the model spent its entire output budget thinking and returned no answer, with 24 of 25 calls hitting the cap on the second. An unmatched pair therefore does not produce a noisy comparison; it produces a comparison of the flag.

Three further rules were adopted after each one caught something, and all three are cheap. The first is to measure a mechanism’s firing rate before its effect. The confidence cap fires on 0.82% of techniques, so an ablation of it would describe the 99.2% where the cap never ran, while the sink-reachability hint fires on 56.7% of samples and an ablation of it is a real statement about the hint; the cap’s own preconditions explain its rate, since it applies to three technique families only when the sole contributing layer is static and 84% of those claims are YARA-only. A corollary is that an ablation must be restricted to the samples where the mechanism fires and must report the remainder separately, because averaging a feature over inputs it never touched dilutes a real effect toward zero. The second rule is to count how many distinct outputs the N inputs produced, and to report that count as a result column rather than run it as a test, because the signal exists only in the batch while each individual response is well-formed and plausible; we report 63 distinct call-graph sizes across 97 samples. The third is to retain per-sample outputs for every study, since aggregates cannot be re-interrogated: when a defect was found that might have affected a completed 210-sample study, the question could not be asked because only the summary survived.

Shared, long-lived servers accumulate state that crosses sample boundaries, so the reverse-engineering server is restarted between samples; in our sweeps that recovered 12 of 14 samples previously recorded as unmeasurable, the failures belonging to the state each sample inherited from its predecessor rather than to the samples themselves. Two audits were added for the same reason and both caught real errors. Diffing the claim register against the evidence log found a claim recorded as novel one hour after our own text called it a replication, an audit row mis-attributing a model caveat to a server-free harness, and three ledger rows carrying superseded figures. Counter-searching each novelty claim in an adjacent field’s vocabulary demoted five claims, including the one central to this paper, and produced two rules of its own: a search summary is a lead and not a source, one having asserted prior art that neither candidate paper contained when fetched; and the result of a counter-search is recorded whether or not it demotes anything, because a searched absence is only credible if the looking is documented. Taken together these practices cost a measurement before every ablation, ~660 MB of retained sandbox reports for one cohort, ~20 seconds of restart per sample, and one line of arithmetic per batch.

2.6. *Statistical analysis*

Every arm sees the same samples in the same order, differences are computed per sample and then aggregated, and 95% bootstrap confidence intervals are taken over the paired deltas. The observations are nested, with many claims from one sample and many samples from one family, so the bootstrap resamples whole clusters and the p-value comes from flipping the sign of whole cluster means rather than of

rows. Two properties of that test are reported with it. With k clusters the two-sided version cannot return a p below $2/2^k$, which at $k=5$ is 0.0625 and puts $\alpha=0.05$ out of reach whatever the effect size; and above 20 clusters the 2^k assignments are sampled rather than enumerated, at 20,000 draws with the observed assignment counted in its own reference set, so the smallest p that route can return is one over the draws rather than zero. Each reported p names which route produced it. The two properties pull in opposite directions, because raising the cluster count lifts the floor and is also what makes enumeration stop being possible; that is why the consensus arms were re-run one sample per family. Multiplicity is controlled with Benjamini-Hochberg over two declared families, and every null is reported with the minimum detectable effect of the design that produced it at 80% power, because a null without its resolution reads either as equivalence or as a failed experiment depending on the reader.

Two of these choices were corrections rather than plans, and both are stated as such. Every interval in an earlier draft resampled rows rather than clusters, and correcting that widened the anchor interval 2.32-fold. And an early study ranked prompt structures using a single-run parsed-claim count, whose ranking inverted when the decoding budget changed, so the instrument was measuring the interaction of structure and budget while being read as measuring structure. A claim count from one run is not an instrument, and no result in this paper rests on one.

3. Results and discussion

3.1. The no-LLM baseline, and the pipeline against it

Every accuracy number in this work is read against one reference, stated before any of our own: the sandbox the pipeline is built on, mapping its own signature hits to ATT&CK technique identifiers deterministically, with no language model anywhere. Table 4 reports it together with the like-for-like comparison against the pipeline.

Table 4: The no-LLM baseline, and the pipeline against the engine it is built on. Both blocks are scored per sample against family-level MITRE ground truth by the same code; intervals resample families, not samples.

	mean	95% cluster CI	ICC	effective n
<i>baseline alone, n=97 samples over 24 families</i>				
precision	0.2413	[+0.1850, +0.3010]	0.584	35.0
recall	0.1328	[+0.0896, +0.1810]	0.638	33.0
F1	0.1526	[+0.1114, +0.1998]	0.692	31.2
<i>paired, n=13 samples over 8 families, F1</i>				
CAPE alone, no language model	0.1130	[+0.0654, +0.1624]		
pipeline, static evidence only	0.1130	[+0.0770, +0.1543]		
pipeline, with the sandbox report	0.1160	[+0.0823, +0.1485]		

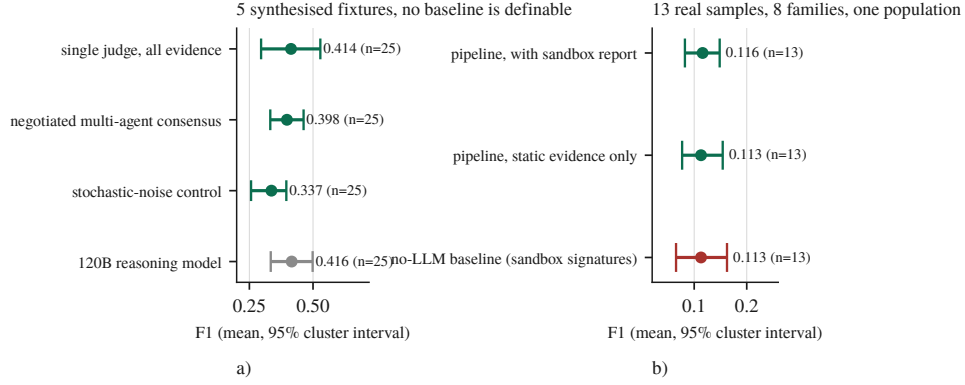


Figure 1: Every measured arm on one F1 axis. a) the synthesised fixtures, b) the real-sample population. Points are means over per-sample F1, bars are 95% intervals resampling the cluster the observations are independent at.

The baseline block covers 97 samples over 24 families, mean 4.04 samples per family, with the bootstrap seed recorded alongside the interval. CAPE asserted at least one technique on every sample, so this is a predictor rather than an artefact of an empty one. Ground truth is resolved per family, so two binaries of one family are scored against a byte-identical label vector and are not two observations; resampling samples rather than families gave an F1 interval 2.32 times narrower on data whose intra-cluster correlation is 0.692, which is why the row count is 97 and the count that supports an inference is 31.2.

Three analyst agents, a negotiation loop, a revision pass, an LLM judge and a weighted corroboration cascade land +0.0030 F1 from the signature engine they are built on top of, 95% cluster CI $[-0.0353, +0.0344]$, exact cluster sign-flip $p = 0.9609$, better on 7 of 13. Two of the means agreeing to four decimal places is a coincidence, and was checked rather than reported: the samples differ individually in both directions, so the system is not reproducing the sandbox’s answers but reaching different answers of the same quality. The interval is what should be read rather than the point. At 8 families this design could detect a difference of 0.085 F1 at 80% power and did not detect one, which bounds the pipeline’s contribution rather than demonstrating that it is zero.

The cohort is 97 rather than 100 because the sandbox reported every task of the submitted batch complete and 56 of them had not run at all. Re-submitting recovered 54; the mechanism and the timing evidence are reported as the fifth boundary case in Section 3.6.

The two panels of Figure 1 deliberately do not share an axis. An earlier version put all five arms on one scale, where a no-LLM baseline near 0.1526 beneath treatment arms near 0.4136 read as a large pipeline win. It is not one: panel a)’s arms run on 5 synthesised fixtures whose evidence is generated from their own technique lists and are scored against per-sample truth, while the baseline runs on real binaries scored against family-level truth. No baseline is definable for panel a) at all, since

a deterministic regular expression over the dictionary that generated its evidence scores 1.000 there by construction. Panel b) is the comparison that can be made, and its three intervals overlap.

3.2. Multi-agent consensus at equal budget

Three arms at an equal total token budget, including a stochastic-noise control in which one analyst receives irrelevant evidence, run first on the fixtures and then again on real binaries one per family so that every cluster holds a single observation. Table 5 reports both.

Table 5: The equal-budget consensus arms, on synthesised fixtures and on real binaries. The real-sample block is scored against the same family-level ground truth as Table 4; the fixture block is not comparable to it.

arm	mean F1	rows	output tokens	× single
<i>5 synthesised fixtures</i>				
single judge, all evidence at once	0.4136	25		
negotiated multi-agent consensus	0.3975	25		3.2
noise control	0.3366	25		
<i>24 real samples, one per family</i>				
single judge	0.0967	1	39,986	1.00
negotiated consensus	0.1503	4	110,395	2.76
noise control	0.1498	4	94,388	2.36

On the fixtures the negotiated arm returns a paired delta against the single judge of -0.0161 , 95% cluster CI $[-0.1247, +0.0819]$, an interval containing zero, at $3.2\times$ the tokens. This design could have detected 0.223 F1 at 80% power and the observed difference is two orders of magnitude smaller, so the null is a bound on what the design could see rather than a demonstration of equivalence. The noise control moves by -0.0770 , $[-0.1337, -0.0233]$, with every one of the 5 samples in the same direction, but that effect is also below the design’s own minimum detectable effect of 0.120 and the exact cluster permutation test returns $p = 0.0625$, the smallest p available, because at 5 clusters the two-sided sign-flip test floors at 0.0625. An earlier draft read that separation as proof of sensitivity; it does not carry that weight, and the honest statement is that all 5 samples moved the same way.

The real-sample replication is where the design can see. At 24 clusters the sign-flip floor is 0.00005 rather than 0.0625. Both multi-agent arms beat the single judge and neither beats the other: negotiated minus single is $+0.0537$, 95% cluster CI $[+0.0362, +0.0714]$, $q = 0.0001$, better on 19 of 24 families, while noise minus single is $+0.0532$, $[+0.0235, +0.0833]$, $q = 0.0040$. The contrast that isolates the mechanism returns nothing, and this time that means something: negotiated minus noise is $+0.0005$, $[-0.0294, +0.0312]$, $q = 0.9751$, on a design that resolves 0.046 F1 at 80% power. The effect the negotiation would have to carry, the $+0.0537$ its neighbours show, is above that resolution, so if the negotiation were doing the work this design would have seen it. What separates the multi-agent arms from the single

judge is therefore the thing they share: 4 model calls instead of 1. Spending more calls on a sample helps; making them argue does not, at this budget, on this corpus, with this model.

The two corpora gave opposite signs, which is the sharpest evidence we have about the fixture corpus. On fixtures the noise control ran -0.0770 against the single judge and was worse on every sample; on real binaries it runs $+0.0532$ and is better, at the same q as the negotiation. Nothing about the arms changed between the two runs and the evidence did. A corpus whose inputs are generated from its own answer key does not merely have less power than one of real binaries; it can rank the arms the other way round.

3.3. Model scale, quantisation and the reasoning flag

Table 6 reports the local model against a $3.4\times$ larger frontier model on the same fixtures at the same 2,400-token output budget, and against the same weights hosted at full precision by their vendor with and without the reasoning flag.

Table 6: Model scale, quantisation and the reasoning flag, all paired against the local arm on the same 5 fixtures and repeats. The local arm is Qwen3.6-35B-A3B at IQ3_K_R4, the frontier arm Nemotron-3-Super-120B-A12B, and the vendor-hosted arms the same Qwen weights at full precision.

arm	think	F1	vs local	95% CI
local, 3-bit	off	0.4136		
frontier, $3.4\times$ larger	on	0.4162	+0.0026	$[-0.1322, +0.1460]$
frontier, flag requested	on	0.4149	-0.0014	$[-0.0695, +0.0799]$
vendor-hosted, full	off	0.3507	-0.0629	$[-0.2133, +0.0963]$
vendor-hosted, full	on	0.0080	-0.4056	$[-0.5232, -0.2880]$

A $3.4\times$ larger reasoning model, given the same evidence and the same nominal output budget, lands within three thousandths of F1 of a 35B model quantised to run on one desktop GPU, and its direction across samples is a coin flip, better on 12 and worse on 13 of 25 rows. That null is a bound: the design could detect 0.300 F1 at 80% power, coarser than every architectural effect reported here, so it says nothing about the $+0.0026$ it returned. It is also confounded and the confound cannot be removed on that endpoint. The local arm runs with its reasoning stream disabled, necessarily, because the local server otherwise returns an empty answer, while the frontier arm ran with reasoning on and spent 56.5% of its budget there. Re-running it with the reasoning parameter set, the provider accepted it and ignored it: 56.2% of the output was still reasoning, and the re-run replicates the original configuration rather than correcting it. The frontier arm was not a collapsed arm, having parsed 25 of 25 calls with no refusals and 1 hitting the output cap, so the null is not an artefact of a dead arm; it is simply not the single-variable comparison it appears to be.

Two results follow from the vendor-hosted rows, and the first is weaker than it first reads. We cannot detect a quantisation penalty and cannot rule out a large one: the paired difference is -0.0629 on an interval of $[-0.2133, +0.0963]$ at $n=25$,

which admits a penalty of up to 0.2133 F1 against our local deployment, and the design’s minimum detectable effect is 0.331. What the data support is that 3-bit quantisation is not demonstrably this pipeline’s handicap, not that it is not one. Second, the reasoning flag replicates at +0.3427 paired ([+0.2008, +0.4936]) on a second model, this time the one we host, with 24 of 25 calls exhausting the output budget on reasoning. A third endpoint bounds the same effect independently: with reasoning enabled it spent 99.9% of every call’s budget thinking and scored 0.0000 across 25 calls, and with reasoning disabled the same model scored 0.4501, so the flag is worth +0.4501 F1, [+0.3604, +0.5437]. The flag is the only effect in this paper that exceeds its own design’s minimum detectable effect, at 0.310 here and 0.200 on the third endpoint. The largest effect measured on any arm is a configuration flag, not an architecture and not a parameter count. Two qualifications belong with it, because it is the paper’s one positive result: the flag comparisons are post-hoc, run after the confound was discovered, and corrected as a family of 5 their q-values are 0.1042 and 0.1042; and like every comparison on this corpus they sit at the exact test’s floor of 0.0625.

We report the frontier null because the literature’s prior predicts otherwise, parameter size being the only statistically significant predictor of ATT&CK-classification F1 on the nearest task [47] [preprint]. We cannot test that as a series either, because a rank correlation over model size needs the arms matched on the flag worth more than the size effect, and the only endpoint above 35B does not permit that match, leaving two configuration-matched arms that are both 35B. An earlier version of the frontier arm reported 0.5025 and was wrong to suggest a lead: that figure came from $n=9$, the run having been cut short by a daily request quota, and the apparent advantage did not survive completing the sample. It was caught by finishing the run rather than by any insight. Where the larger model’s budget went is on the record too: across 25 calls, 56.5% of output tokens were reasoning, and on a one-token answer 84%, at 92 output tokens of which 77 were thinking.

3.4. *Retrieval, confidence, and firing rate before effect*

Three retrieval components were built independently, each works where it was built, and each moves nothing where it is wired in. Table 7 reports all three in isolation and end to end.

The first row needs a qualification before the pattern can be read. Its isolation figure is not accuracy, because the leave-one-out corpus is labelled with the pipeline’s own prior attributions, so scoring the index against it measures agreement with its own upstream; it is retained because the comparison survives that, a frequency prior scored the same way on the same labels reaching 0.424, and because the production column beside it is scored against MITRE ground truth on held-out samples. The three then fail for three different reasons, which is what makes the pattern worth reporting rather than three disappointments. The first fails on vocabulary mismatch between query and corpus, visible only in the score distribution while top-k accuracy stayed healthy. The second is simply small. The third fails for two independent reasons: its corpus holds 3 samples under 2 generic labels, and the 8-instruction

Table 7: Three retrieval components, each measured in isolation and again end to end.

component	works in isolation?	contribution end to end
ATT&CK	self-consistency 0.620 against a	loses to the frequency prior in
case-prior RAG	0.424 frequency prior, scored on the corpus’s own prior attributions rather than on MITRE ground truth	production (0.111 against 0.123, MITRE ground truth)
family-feature	yes, recall@5 0.199, 6.3× chance,	+0.0029 F1, precision
RAG	leakage-free split	−0.0088, n=19
opcode-hash	n/a, never fires	0 of 18 samples; 7,716
attribution		functions hashed, 0 matches

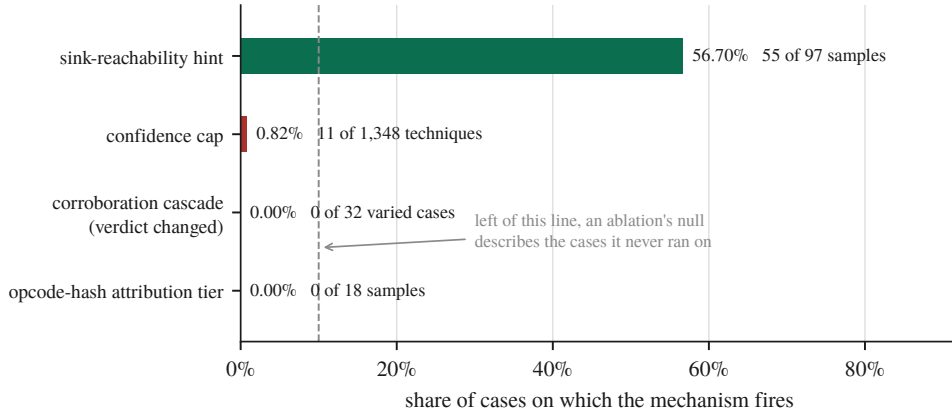


Figure 2: Firing rate decides whether an ablation can be read at all.

floor that correctly excludes thinks leaves 9 of 18 real samples with one hashable function or none, a sharply bimodal distribution that populating the corpus would not fix.

Verbal confidence, which the cascade and every deterministic gate consume, discriminates correct from incorrect claims at AUC 0.550, near chance, concentrated on 4 round values. Resampling samples rather than claims puts the interval at [0.475, 0.671], which contains chance, and 3 of the 5 samples sit at or below chance individually, with the pooled figure carried by the one that reaches 0.778. Figure 3 shows why: 186 of the 210 claims carry confidence exactly 1.0, so the score has almost no ordering to contribute. The estimate is rank-based with ties averaged, which for this distribution is not a detail, since sorting the tied claims arbitrarily instead returns 0.458 and the difference between the two numbers is entirely an artefact of how 89% of the data is handled. This matches arXiv:2606.29490’s finding that verbal confidence measures willingness to commit rather than correctness, and it means every deterministic gate keyed to that number is keyed to something we cannot distinguish from noise.

Whether any of these mechanisms can be ablated at all depends on how often it engages, which Table 8 and Figure 2 report. Three of the four mechanisms the ar-

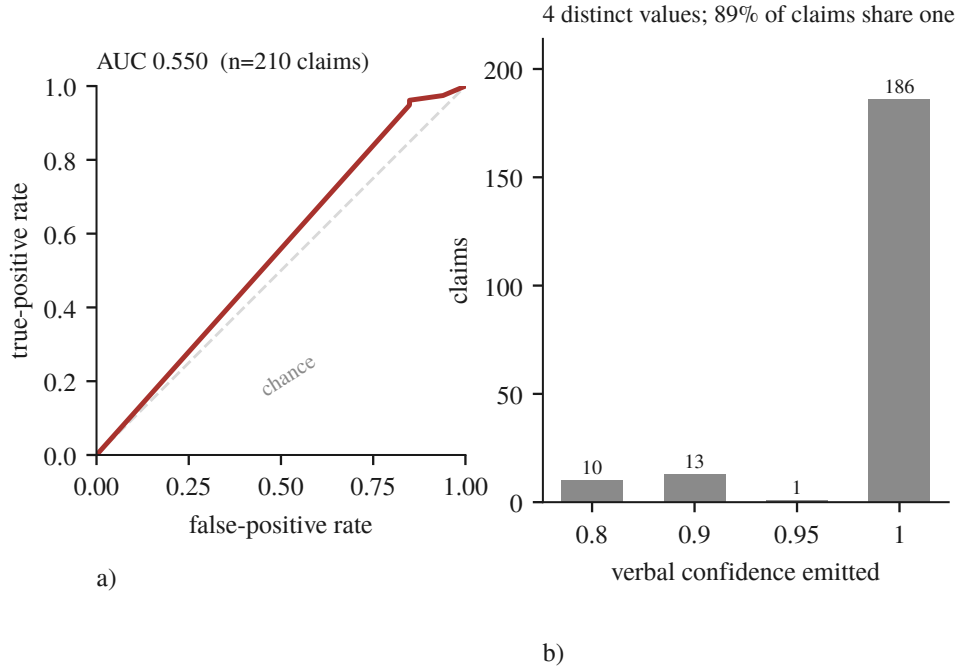


Figure 3: The number the gates consume barely orders anything. a) the ROC over 210 claims against resolved ground truth, b) the confidence actually emitted.

chitecture was built around engage on almost nothing, so an ablation of any of them would return a null describing the cases where the mechanism never ran. Only the sink-reachability hint clears a rate at which an ablation carries information, which is why it is the one we ablated.

Table 8: Firing rate before effect, and the one ablation it justified. Units differ per row of the lower block and are named in the row.

mechanism	fires on	consequence
confidence cap	0.82% of techniques	an ablation would measure nothing
sink-reachability priority hint	56.7% of samples (55/97)	an ablation is interpretable and was run
STIX integrity pass	60 fresh judge bundles	reported by removal reason
outcome of the hint ablation	mean Δ (on – off)	95% CI
distinct technique IDs	+0.50	[−3.33, +4.50]
claims	−0.83	[−4.33, +3.67]
seconds	+52.55	[−161.93, +268.45]

The hint does nothing measurable. On $n=6$ pairs it is better on 2, worse on 2 and tied on 2, with per-pair deltas of +9, +4, 0, 0, −4, −6, large in both directions

and cancelling. This is the fourth architectural claim to end in a null and the last one we were in a position to test.

The result that constrains that result is that half the experiment was not scoreable. Twelve pairs were attempted and 6 survived screening: 3 were lost to degenerate decode, an arm emitting 49 to 117 claims across 2 to 14 technique IDs at ratios 8.4 to 34.3; 2 were unattributable, both arms dead with the host state needed to decide whether the pipeline or the machine failed never recorded; and 1 were incomplete, an arm exceeding the 630 s bound, which is a genuine outcome that still costs the pair. A 50% pair-loss rate bounds what any ablation on this pipeline can detect, and quoting +0.50 [−3.33, +4.50] without it would claim a precision the instrument does not have.

The two unattributable pairs are this paper’s own retention rule recurring against it. The run halted at 10 of 24 arms and they died under host memory pressure, with 2.3 GB of the model server’s address space paged out, which Section 3.9 reports as a threat in its own right. We had retained per-sample outputs, as our own rule requires; what went unrecorded was the environment the measurement ran in. The harness now captures MemAvailable, SwapFree and the server’s resident-versus-swapped split at both ends of every arm and the scorer screens on it, forward only, never for data already collected. Three arms failed outright: two carried a Connection error from a restart race, meaning the measurement never happened, and were re-run, contributing a −4 against the hint; the third was the 630-second timeout, which is an outcome, and deleting an outcome one dislikes is selection rather than repair. Running the ablation also surfaced a production defect that 2,744 passing tests did not, described as M4 in Section 3.6: on any binary rich enough to exhaust the 40-step ReAct budget the analyst returned zero techniques, because the salvage path received a fresh copy of a budget it was already inside. Fixed and verified on the same sample, from 1,677 s to 323 s and from 0 to 5 technique IDs. The fix is partial: one sample still exceeds the bound, and the server’s own timings show generation varying from 162 to 20 tokens/s on this hybrid recurrent architecture, so a bounded input does not rescue a case where the tokens themselves are eight times slower than assumed.

3.5. *The corroboration cascade does not reach the verdict*

The multi-layer corroboration set is the design’s central claim about evidence quality. We remove one Layer-0 source at a time and compare the bundle the analyst receives against the bundle produced with all of them, under two conditions differing in exactly one respect: whether the removed source was the sole owner of its techniques. Under *disjoint*, where its techniques disappear because nothing else claims them, the verdict changes in 32 of 32 arms at Jaccard 0.750 [0.714, 0.800] against all sources. Under *overlap*, where the techniques survive under a partner source but their corroboration changes, it changes in 0 of 32 at Jaccard 1.000 [1.000, 1.000]. Take a technique away and the bundle loses it; leave the technique in place and destroy the cross-domain agreement behind it, which is the thing the cascade exists to compute, and the bundle is byte-identical.

The reason is not the one we first wrote, and the correction is M5 of Section 3.6. The judge is not what makes the bundle behave this way. The reconciliation step drops every `attack-pattern` whose technique ID cannot be resolved and appends every cascade technique missing from the bundle, so the cascade’s set is a guaranteed subset of every bundle the system emits whatever the judge produced. Recomputing each arm’s cascade set from the same seeded fixtures shows the bundle is exactly that set in 80 of 80 arms, with the judge contributing zero techniques to any of them, so both conditions follow from set arithmetic rather than from restraint. The Jaccard was the tell we missed, for the reason M5 gives.

That bound was stated rather than the stronger claim it invites, because the evidence could not distinguish a judge whose output was unusable and wholly replaced from one that reproduced the cascade’s set exactly. The measurement has since been taken, by intercepting the reconciliation step and recording what the model produced before the deterministic set was merged in. Table 9 reports it on the four calls that reached that step. Three of the four produced nothing nameable at all; the fourth named twelve techniques, every one already in the cascade. Three quarters of the model’s own attack-patterns asserted a behaviour it could not map to a technique and were discarded. The bundle is the cascade’s set wearing the judge’s name.

Table 9: What the judge contributed to the artefact the analyst receives, intercepted at the reconciliation seam. Counts are techniques, over four calls.

	total	per call
attack-patterns the judge emitted	50	12.5
carrying a resolvable ATT&CK ID	12	3.0
dropped, the model named no technique	38 (76.0%)	9.5
IDs the cascade did not already hold	0	0.0
injected because the judge omitted them	87	21.8

Half the calls never reached that step. Four of the eight timed out at the verdict ceiling, and on a timeout the verdict tool returns a text-fallback bundle that never calls the reconciliation routine, so the cascade is not consulted on that path at all. The timeouts are not a property of the fixtures: the judge’s 8,192-token output cap was renamed by our client library to a parameter the local inference server does not read, so the model decoded unbounded until the caller gave up, described as M7 in Section 3.6. One such call was measured at 30,155 generated tokens and was still going.

Repeating the study with the cap fixed turns the pair into a controlled experiment, and the result inverts this section’s own conclusion. With the ceiling binding, the same four fixtures fail and the same four succeed, the judge’s share of the bundle is 0.0% in both conditions, and every number on the reconciled path is identical; what changes is only how the failure arrives, 8,192 tokens of unparseable output in three and a half minutes instead of a ten-minute timeout. The artefact is not the same, however. The fallback builder scrapes ATT&CK IDs from the evidence

claims and from the model’s own raw response. In the uncapped condition that response is the literal string [TIMEOUT] and contains no IDs, so the fallback bundle was exactly the evidence-derived set, identical to the cascade set on all four calls. In the capped condition it is 18,748 to 24,710 characters of degenerate decode, and Table 10 reports what then reaches the analyst.

Table 10: Techniques reaching the analyst on the text-fallback path against those the corroboration cascade held, per fixture. The last column is the set no evidence source corroborated.

fixture	fallback	cascade	only in fallback
jhuhugit	32	20	12
sardonic	27	25	2
sliver	46	23	23
wannacry	26	16	10

47 techniques reach the analyst that the corroboration cascade never held, and none goes the other way; on one sample the bundle doubles. Because the uncapped run is a control whose raw text provably contains no IDs, every one of them is attributable to the model’s own output, and they passed through no filter at all: not the cascade, not the reconciliation step, not the invalid-ID filter, not the integrity pass. Checked against the 691-technique ATT&CK catalogue they are also real, 45 of 45 unique IDs existing and none invented. That removes the easy reading. The pipeline is not emitting hallucinated identifiers a schema check would catch; it is emitting genuine ATT&CK techniques that no evidence source claimed and no corroboration supports, in the same object type and the same bundle as techniques three independent sources agreed on, with nothing downstream to tell them apart. So the finding needs its scope stated exactly. The judge has no influence over which techniques reach the analyst on the path where it works, and more influence on the path where it fails than on the path where it succeeds, 0 of 99 techniques when reconciliation runs against 47 of 131 when it does not. The architecture suppresses the model’s contribution precisely when the model is functioning, and admits it precisely when it is not.

This replaces an earlier version of the same result, and the replacement is why we trust it. The first pass varied three of six Layer-0 sources over fixtures carrying five techniques and reported the verdict unchanged in 0 of 15 cases. Two defects were found in it afterwards: the absent sources included the Sigma layer, which fires on 94 of 97 samples at weight 0.55, above every static layer that study did vary; and at five techniques over six sources the round-robin assignment left one source with nothing, so its arm matched the baseline by arithmetic rather than by measurement. The re-run uses fixtures of 12 to 51 techniques so every source carries at least three claims, includes the Sigma layer, and adds a corroborated pair that does not involve YARA. The null survives all of it, at 32 arms rather than 15. One pre-registered prediction resolved in both directions: removing the tool-artifact layer should change nothing, because it emits on YARA’s cascade domain and cannot contribute cor-

roboration, and under overlap that is exactly right at 0 of 8 while under disjoint it is wrong at 8 of 8, because there the source solely owns its techniques. The prediction holds precisely where corroboration is the only thing varying, which is the sharpest evidence we have that the two conditions measure what we claim.

3.6. Instrument failures

Seven failures of the instrument are reported together because they share a shape a test suite is poorly positioned to catch and a results table cannot show: the instrument answered successfully, and answered about something else. Table 11 lists them with the layer each occurred at and what actually found it. The first four crossed a boundary with another server. The last three are ours, two in the analysis code that produces our results and one in the pipeline that produces the artefact the analyst receives, and the shape therefore stops neither at the network boundary nor at the evaluation harness.

M2 is the mechanism the others are read against, because the response contained the correct program name, which is what made it convincing. The server maintains a separate notion of the current program and `load_program` sets it only when nothing is current yet:

```
load A      -> {"success": true, "program": "A"}   current: A
load B      -> {"success": true, "program": "B"}   current: A  <-- still A
run_analysis -> {"program": "A", "new_functions": 0}
call graph  -> A's graph, byte-identical, for every sample
```

From the second sample of a container's lifetime onwards, the decompilation, the imports, the strings, the call graph and the function hashes all described the first binary while the report named the current one. M1 and M3 are the same shape at neighbouring layers. M1 survived to first contact because the reverse-engineering server, the only one that client had ever talked to, declares no optional parameter with a typed default, so a defect in shared client code was invisible while only one of the two servers it served had ever been exercised. M3 is error swallowing in the ordinary sense, `raise_for_status()` seeing nothing wrong in `{"error": "Failed to load program from: ..."}` returned with an HTTP 200. M4 composed two bounds that were each correct alone: exceeding the step budget guarantees an attempt at the salvage, the salvage received a fresh copy of the full time budget, and the composition was never considered.

The fifth boundary case is the one that was caught before it produced data, and the difference is the argument of this paper. Fetching the sandbox cohort's reports, a request for a report the sandbox has since deleted is answered with HTTP 200 and a 63-byte body reading `{"error": true, "error_value": "Reports directory does not exist"}`. Fifty-six of one hundred tasks answered that way. A fetcher trusting the status code would have written those bodies into the archive under the filename of the sample they were supposed to describe, and the three studies reading that archive would each have scored them. It did not, because the fetcher verifies the report's own `target.file.sha256` against the identifier it asked for before writing

Table 11: The seven instrument failures, with the layer each occurred at and what found it.

	what the instrument did	layer	what found it
M1	an optional argument the agent never supplied arrived as an explicit <code>null</code> , and a field typed <code>str</code> rejected it, failing all 36 tools	sandbox MCP client	every call returning the same validation error
M2	<code>load_program</code> answered success without changing the server’s current program, so everything derived from it described the first binary of that container’s lifetime	reverse-engineering server session state	call graphs identical to the character across unrelated samples
M3	a load the server could not perform answered HTTP 200 with an error in the body, so downstream code analysed whichever program remained current	HTTP status against body	66 consecutive samples at exactly 75,426 characters
M4	a 40-step ReAct budget and a wall-clock cap composed into a path that returned zero techniques, at 28 minutes per attempt	two local bounds	a 25-minute call always producing one claim and zero techniques
M5	an ablation varied a deterministic reconciliation step and the output was attributed to a language model	our analysis code	a Jaccard too clean for a model to produce
M6	a rank correlation over model size ranked a reasoning-configuration flag instead, recovering the published scaling coefficient	our analysis code	reading the arms table under the correlation
M7	a documented output ceiling was renamed during serialisation to a key the server does not read, so a component described as bounded was never bounded	our production pipeline	a study recording which failure branch each call took

anything, a check that exists only because M3 taught us the shape, and it cost four lines. We first recorded the consequence as a retention limit, that the reports had existed and expired. That was wrong, and finding out how wrong is the finding. Asking the sandbox how long each analysis had taken produced a split with nothing between the modes: the 43 tasks whose reports survived ran 186 to 366 s and the other 56 ran under a second, all 56 of them still marked reported. A Windows PE does not detonate in one second. Nothing had expired; nothing had happened, and the instrument said otherwise. Re-submitting the same binaries two days later produced full-length analyses on the same instance, recovering 54 and putting the cohort at 97, while the remaining 3 produced no report on either attempt and none

of them failed, all 3 being still marked reported at zero seconds with no report directory. A completion status is a statement about a queue rather than about an analysis, and it is exactly as trustworthy as an HTTP 200. The retrieval path now reads each task’s wall-clock duration and refuses anything under 60 s before it will accept a report.

The last three crossed no boundary. M5 is the only one that reached a results table. We ablated the corroboration cascade and wrote the two conditions of Section 3.5 up as a finding about the judge, that it attends to the list of claimed techniques and ignores the evidence-quality apparatus above it. The judge was not involved: the reconciliation step makes the cascade’s set a guaranteed subset of every bundle whatever the model produced, so both numbers are necessities of an if statement rather than measurements of restraint, and the experiment could not have returned anything else. A second study, already written and about to run, would have compared a weighted cascade against a flat union of the same claims, and both of its arms would have shared one reconciliation set, so it would have reported no difference after an hour of computation, correctly and vacuously; it was stopped four minutes in by the same log line that exposed M5. What made this hard to see is that the tell was in the results the whole time. A Jaccard of 1.000 with a zero-width bootstrap interval across 32 ablated arms at temperature 0.1 is not something a language model produces; it is what a constant looks like. We read it as an unusually clean null, because a clean null was the result we were prepared to find.

M6 is the only one whose wrong answer agreed with the literature. Assembling a parameter-size series to test the published finding that parameter count predicts ATT&CK-classification F1, the harness ranked mean F1 against total parameters across a 3.4× span and reported $\rho=+0.866$, reproducing the prior almost exactly, with the confounds it could not remove printed honestly beneath. The five rows were three models, one appearing twice because it had been run in two configurations. That was not a labelling detail: the same weights score 0.3507 with the reasoning stream disabled and 0.0080 with it enabled, because 24 of 25 calls then spend their entire output budget reasoning and never answer, and the enabled row sat at the small end of the parameter axis where it set the sign. The failure is not the duplicate rows but that the arm-selection rule did not exist. The harness had averaged ranks so file order cannot break ties, an exact permutation p because four points cannot reach significance, and a common-cell restriction so endpoint availability cannot masquerade as model size. Every one of those guards was about a way the numbers could mislead and none was about whether the rows were comparable in the first place. The rule now keys on the measured reasoning share of each arm rather than on the flag requested, because those two disagree; with it applied, two arms qualify and both are 35B, so the series refuses and says which arm was excluded and at what measured reasoning share. M5 was caught by a number too clean to believe; M6 produced a number in exactly the range a reader would expect, in the direction the literature predicts, with its limitations already stated. There was nothing anomalous to notice, and it was caught by asking why one model was on the arms table twice.

M7 is in the production pipeline rather than in an evaluation harness, and it re-

moved a guarantee the code states in its own comment. The judge is built with an 8,192-token output ceiling, and the line that builds it says why: to bound the verdict generation so a degenerate decode cannot consume the full wall-clock timeout. The client library renames that parameter to the vendor’s newer spelling when it serialises the request, and the local inference server does not read the newer spelling. It accepted the field, ignored it, and decoded without a ceiling. Measured on one call: a 1,403-token prompt, 30,155 tokens generated, still generating at 46 tokens per second when the caller’s ten-minute wrapper gave up. The consequence is not a slow call. Four of eight fixtures in a separate study never returned a verdict, and for each the pipeline emitted a bundle through its text-fallback path, which does not run the reconciliation step, so the corroboration cascade contributed nothing and the analyst received techniques copied straight from the raw evidence claims. It was invisible because the configured value was correct at every level anything reads: the container passed it, the model object held it, and it survived every later rebinding intact. Only the serialised request was wrong, and nothing in the system reads the serialised request, so every check anyone would think to perform would have confirmed the property that did not hold. What found it was neither a test nor a review but a study measuring something else, which recorded which branch each failed call took rather than only that it failed. Four calls named the timeout branch, which prompted the question of why a temperature-zero model would need ten minutes. The instrumentation that caught it had been written for a different question three hours earlier. The incompatibility itself is known, reported against `llama.cpp` and `vLLM` in their own issue trackers [53, 54] [preprint], one of which has since closed the gap; what one costs inside a measurement is the part we report.

That 2,744 tests passed throughout is a fact about test shape rather than test quality. M2 and M3 require a second case within one server lifetime, and a unit test loads one program, asserts, and tears down, so the state that goes wrong is created by the second call and cannot exist in a single-call test. M1 required a second server, and the behaviour was correct against the only server exercised. M4 required an input rich enough to exhaust the step budget, which small fixtures never are. Preconditions of that kind are exactly what a fast unit suite is designed to avoid. The last three are worse than avoided and are invisible to unit testing in principle, because every unit involved behaved as specified: M5’s reconciliation function has unit tests asserting exactly what it does and was never wrong, and no test of a component can catch a misattribution made three modules away; M6 was tested more carefully than anything else in the harness and every guard concerned the wrong question; and M7 had nothing left to assert on, since a unit test would check that the output ceiling is 8,192 and it is, at every level the object model exposes.

3.7. Output cardinality as a detector

Five of the seven were found by the same observation, a number that repeated where variation was expected. Table 12 lists what the check saw and which defect each observation turned out to be. M6 and M7 were not found this way, because their outputs vary and there is no repetition to notice.

Table 12: What the output-cardinality check saw and which defect each observation turned out to be.

observation	defect
a priority hint of exactly 2,575 characters for two unrelated binaries, and a third in an earlier session	M2
call graphs identical to the character (404,337 chars, 11,798 lines) for samples of 241 KB and 139 KB	M2
66 consecutive samples at exactly 75,426 characters	M3
every tool call returning the same validation error	M1
a 25-minute call that always produced one claim and zero techniques	M4
a Jaccard of 1.000 with a zero-width interval across 32 ablated arms at temperature 0.1	M5

The generalisation is one line of arithmetic. Before trusting a batch measurement, ask how many distinct outputs the N inputs produced; if far fewer than N differ on a dimension that should vary, such as output length, digest or element count, the instrument is repeating itself, and repetition is what stale state looks like from outside. It needs no ground truth and no oracle, which is what makes it usable exactly where correctness is hard to check, and it is reported as a result column rather than run as a test because the signal exists only in the batch while each individual response is well-formed and plausible. M5 extends it where the idea is least comfortable, because there the repeated number was our own result rather than a server’s response and the variation that failed to appear was the model’s; a perfect agreement is the same signal as an identical digest and deserves the same suspicion.

Plot distinct outputs against inputs processed and a healthy instrument tracks the diagonal while a stuck one goes flat, so the diagnosis is in the shape and no ground truth is required. Panel a) is measured, its staircase’s flat treads being genuinely identical binaries rather than a fault, and that is the figure we now report beside every batch result. Panel b) is a schematic, and the reason is itself the cost of these failures: it depicts M3, the run in which 66 consecutive samples returned a byte-identical 75,426-character call graph, and we cannot plot it because that run predates the per-sample retention policy those very failures caused us to adopt. The curve this paper turns on is the one we are unable to draw.

The price is a completed study. A seven-year 210-sample temporal-drift analysis ran the full pipeline per sample against a long-lived server that was never restarted between samples, which is M2’s precondition exactly, and whether it was affected cannot be determined because its per-sample outputs were not retained. The result had passed review, entered the claim ledger as novel, and was cited internally for weeks. Two policies follow and both are cheap. Retain per-sample outputs for every study, because the withdrawal is caused not by the defect but by the defect plus the inability to re-ask the question afterwards. And restart the shared server between samples, which recovered the samples reported in Section 2.5.

What we claim from all of this is narrower than the category. Silent failure

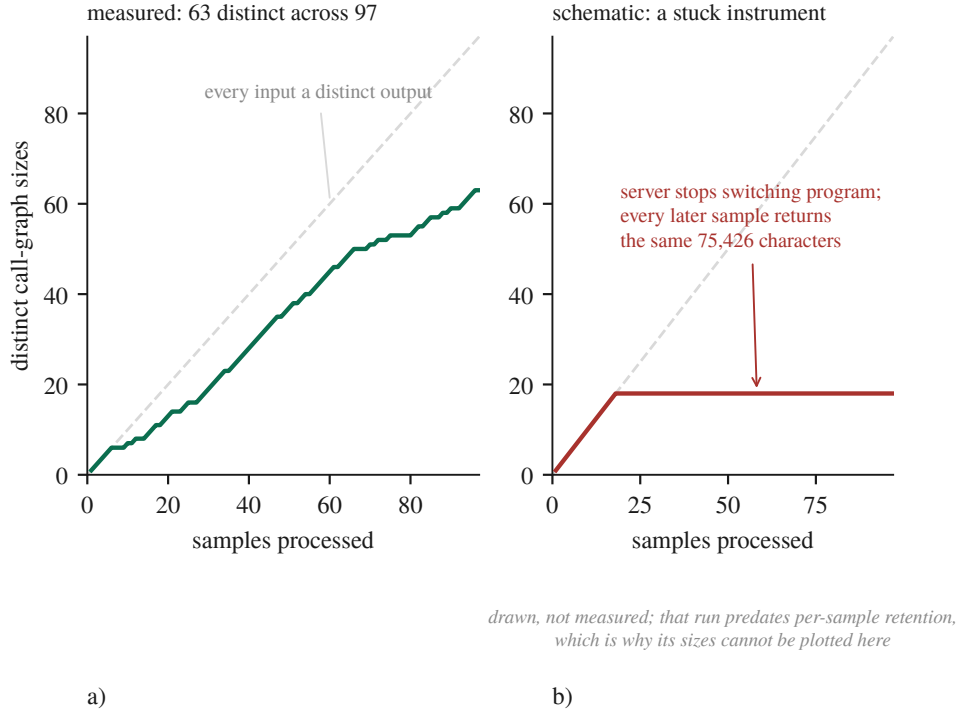


Figure 4: The whole detector, drawn. a) a measured run at 63 distinct call-graph sizes across 97 samples, b) a schematic of a stuck instrument.

at tool boundaries is documented and Section 1.1 places both the detector and the genus in the literature that already carries them. Ours is four mechanisms at four distinct integration boundaries, in argument encoding, server-side session state, HTTP status against body, and the composition of two local safety bounds; the setting, an evaluation pipeline where the failure propagates into a published claim rather than into a support ticket; and a detector run alongside results rather than as a test. M5 and M6 extend that from other people’s servers misleading us to the same shape occurring wherever a measurement’s cause is assigned rather than measured, and M7 shows the shape is not peculiar to evaluation, because there the artefact the analyst receives was affected rather than a number in a table.

3.8. Discussion

The most consequential thing we can say about these negative results is that most of them are bounds rather than equivalences, and that we did not know this when we first wrote them down. Five of the studies reported here run on a corpus of five fixtures, and at five clusters the exact two-sided cluster permutation test cannot return a value below 0.0625, so no comparison measured on that corpus can reach $\alpha=0.05$ whatever its effect size. That is a property of the design rather than of the data, and no number of extra decoding repeats moves it, because repeats add rows inside clusters and rows inside clusters are not what the test counts. Multiplicity cor-

rection is therefore beside the point there: Benjamini-Hochberg over two declared families finds nothing to correct, because there was nothing at $\alpha=0.05$ to begin with. The practical consequence is that a null has to be reported with its resolution. The frontier comparison could detect 0.300 F1 at 80% power and returned +0.0026; both facts are true and only the pair of them is informative, since the second alone reads as equivalence and the first alone reads as a failed experiment. It also changes what the cheap fix is. The instinct on seeing an underpowered paired design is to add repeats, because repeats are cheap and samples are expensive, and on clustered data that instinct is exactly wrong: a sixth fixture would have halved the attainable p, while a sixth repeat on five fixtures moves it not at all.

The literature we counter-searched against locates silent failures at the boundary between modules, and four of our seven crossed such a boundary while three crossed none. What the seven share is not a boundary but an attribution. An ablation varied the deterministic reconciliation step and we attributed the difference to a language model; a rank correlation ordered a reasoning-configuration flag and we attributed the ordering to parameter count; a documented output ceiling was renamed during serialisation and we attributed boundedness to a component that had never once been bounded. In every case the number was real and the arrow pointing to its cause was drawn by us. We offer that as a proposal rather than as a taxonomy, since seven cases from one project is not a class, but it does suggest a different question to ask of an evaluation than boundary-oriented thinking suggests: not whether any component failed silently, but, for each number about to be reported, whether its cause was measured or assigned. The clustered-inference correction of Section 2 is that question turned on ourselves and answered badly, since every interval in an earlier draft attributed its width to sampling variation among independent observations, the observations were not independent, and nothing in the pipeline, the tests or the review caught it because the defect was never in a function.

We are wary of drawing implementation advice from one pipeline on one machine, so what follows is narrow. Measure the firing rate before the effect, because a mechanism that engages on 0.82% of its inputs produces an ablation whose null describes the cases where it never ran; this is the cheapest practice in the paper and it changed which experiments were worth running rather than merely how they were reported. Count the distinct outputs, because that needs no ground truth and no oracle and belongs beside the sample size in a report rather than inside a test. And retain per-sample outputs, then ask what else the study is made of: we adopted retention after losing a study to its absence, the rule was scoped to the object under study, and the next failure was in the environment, where four arms died on host memory and we had their outputs but not the host state. The rule you write after a failure is scoped to that failure.

What we are not in a position to say is worth stating with the same precision. We can say something narrower than that multi-agent decomposition does not help and sharper than the fixture null: on 24 real samples it does help, by +0.0537 F1 over a single judge, and a noise control helps by the same +0.0532, with the two separated by +0.0005 at a resolution of 0.046, so the decomposition into several

calls is worth something here and the negotiation between them is not. We cannot say that negotiation is worthless in general, because a control that matches the treatment tells us where our gain came from and not where anyone else’s must. We cannot say that model capacity is not the ceiling; we can say that a 3.4× larger model did not separate from ours at a resolution of 0.300 F1, that the two arms differed in a configuration flag worth more than any architectural effect we measured, and that the endpoint would not let us remove the difference. We cannot say that verbal confidence is uninformative in general; we can say that in this pipeline it ranks correct claims above incorrect ones at AUC 0.550 with an interval containing chance, so the deterministic gates keyed to that number are keyed to something we cannot distinguish from noise. And we cannot say that our seven mechanisms generalise. What we can say is what each of them cost.

3.9. Limitations and threats to validity

This section is organised around the nine pitfalls of *Chasing Shadows* [37], with two checks added that the survey does not have and that both caught errors here. It begins with damage rather than with hazards. One study is withdrawn, the 210-sample temporal-drift analysis of Section 3.7, which was completed and had entered our claim ledger as a novel result; it is not restated anywhere in this paper. Table 13 gives our exposure to each pitfall with the basis for the verdict, and four of the nine need more than a row.

On P6, truncation enters through chunking at function boundaries, a per-call evidence cap, a 40-step ReAct budget, an 8,192-token verdict cap and a 400-char hint cap, and two findings belong here rather than in the row. The enumeration of truncation sites was itself incomplete: a 20,000-edge cap on the call-graph fetch was discovered only while instrumenting a different measurement, and it silently truncates 1 of 97 samples, so we describe how our list was built rather than presenting it as exhaustive. And bounds compose, as M4 shows; removing a hint made the judge overrun a 600 s ceiling and return an empty bundle 6/17 times.

P8 is the pitfall this work is most exposed to and the one where the evidence has moved. A 120B reasoning model has now run to completion on the same fixtures, repeats, prompt and token budget and did not separate from the local model (Section 3.3); a 3.4× parameter advantage producing no measurable difference is evidence against the pitfall’s usual worry rather than merely an absence of evidence for it. That null is confounded by the reasoning flag and the confound cannot be removed on that endpoint, and what is being confounded is not small, the same flag being worth 0.34 and 0.45 F1 on two separate models. Quantisation is no longer unmeasured under P8 either, the vendor’s full-precision hosting of the same weights scoring −0.0629 F1 against our 3-bit deployment at n=25, an interval containing zero and a point estimate pointing away from the direction the threat assumes; two serving stacks differ alongside the precision, so this bounds the deployment rather than quantisation alone. What P8 cannot close is the size series, for a measured rather than a budgetary reason: testing a parameter-size trend needs three arms at three sizes matched on the flag that outweighs size, the one endpoint honouring

Table 13: Our exposure to each of the nine pitfalls, with the basis for the verdict.

pitfall	verdict	basis
P1 data poisoning	CLEAR	nothing is trained; retrieval corpora are curated and their provenance documented
P2 label inaccuracy	CLEAR	ground truth is MITRE-curated and no LLM scored any result; no human analyst rated any report either
P3 data leakage	PARTIAL	one instance found by us, disclosed and mitigated, but never systematically audited; the model’s training data is unknown to us and memorisation was not probed
P4 model collapse	CLEAR	augmenting the long-term memory corpus with LLM-generated cases was considered and refused
P5 spurious correlations	PARTIAL	two were found and are reported; no systematic perturbation testing was performed
P6 context truncation	EXPOSED	truncation is designed in throughout and the counters now exist, but the distribution over a full cohort does not
P7 prompt sensitivity	PARTIAL	a structured prompt-variation study exists, but production prompts are fixed and were not varied per model
P8 surrogate fallacy	PARTIAL	every local result comes from one model on one machine, and a second endpoint has now run to completion against it
P9 model ambiguity	PARTIAL	model and engine are pinned by digest, revision and commit, but the commit was reconstructed rather than recorded

the flag hosts the same 35B model we already run, and the one above 35B does not honour it. Coverage also remains, the second model having been measured on five synthetic fixtures rather than on the malware cohort, which the free tier’s 50 requests/day makes a two-day run or a paid one. P9 is PARTIAL for one reason: the running binary reports its version as unknown and the engine commit was recovered from a vendored copy of the sources rather than read off the artefact (Section 2.4). Build provenance must be captured at build time; ours was reconstructed, and we say so.

The two checks the survey does not include are described as practices in Section 2 and both were added after they caught errors. All nine pitfalls concern the relationship between claims and experiments, and what diffing the claim register against the evidence log caught sat one level below that, needing no literature search but only two of our own documents read against each other: a project disciplined enough to keep both a findings log and a claim ledger has, by that fact, created the conditions for the two to diverge. The second is the output-cardinality check of Section 3.7, which found every boundary defect and which we now report alongside results at 63 distinct call-graph sizes across 97 samples.

A scored component that derives its output from the same source as the labels is scoring a tautology, so this was tested component by component rather than as-

sumed. Ground truth is the MITRE malware uses attack-pattern relationship set, built from the public ATT&CK STIX distribution, so it comes from MITRE and from nothing this project produces. Three components are clear. The Sigma layer reads the technique identifier from each rule’s own `attack.tnnnn` tag, and those rules are community-authored detections with hand-written tags, so Sigma shares ATT&CK’s vocabulary with the labels and not their source. The sandbox baseline, which is the one that would have mattered most, takes its identifiers from class attributes hand-written in each signature module and mapped through the sandbox’s own table, consulting no family attribution anywhere, which is precisely what makes it a valid baseline rather than a second view of the answer. And the retrieval corpora do not overlap the evaluation cohorts, checked by digest rather than by assertion: of the 1,733 cases in the ATT&CK case corpus, none shares a sha256 with the 100-sample dynamic cohort or with the 210-sample drift manifest. One construct problem survives and it is ours: the case corpus is labelled with the technique identifiers the pipeline itself previously attributed, so scoring the index against those labels measures agreement with its own upstream, which is why that number is labelled as self-consistency in Section 3.4 and the conclusion rests on the production figure beside it. There is also one shared vocabulary, named rather than hidden: the catalogue defining valid technique identifiers is the same file that bounds the label universe, so the invalid-identifier rate is measured against the catalogue the labels are drawn from.

Any claim about what the sandbox contributes has to survive one measurement of what the sandbox reports. Across the 97 archived analyses there are 143 distinct network domains and 38 of them appear in every single sample, the analysis VM’s own vendor telemetry, present in each capture whatever was detonated. Per sample, between 55.9% and 79.2% of observed domains are cohort-ubiquitous, median 67.9%, so two-thirds of the network evidence in a dynamic arm is the instrument describing itself and an effect attributed to malware behaviour may be partly an effect of the analysis VM’s idle traffic. The same measurement bounds two Layer-0 sources from the other direction: the LOLBin and DGA layers produced a claim on none of the 95 reports archived when that ablation ran, while being fed a median of 8,667 recorded API calls and 48–68 domains respectively, so neither appears as an arm in the cascade ablation. An earlier version of this measurement, on the 43 analyses that survived before the cohort was recovered, gave 130 domains with 40 ubiquitous at a median share of 71.4%; more than doubling the cohort moved the figure by three points and left the conclusion where it was.

The machine a measurement runs on is part of the instrument, which is a threat we did not anticipate and met late. The working set does not fit a 31 GiB host alongside an interactive session, with the model server holding ~16 GB, the analysis worker ~8 GB and the disassembly container up to 6 GB. During a paired ablation the swap file was exhausted and the model server had 2.3 GB of its own address space paged out; an arm then exceeded a 594-second budget on a prompt trimmed to 16,000 characters. Whether that arm failed because of the pipeline or because of the host cannot be determined, because we recorded the pipeline’s out-

puts and not the host's state, so the affected arms are reported as unattributable rather than as failures and the ablation as incomplete rather than as a null. Three things follow. Wall-clock bounds are host-dependent measurements wearing the costume of a system property, so any result here that turns on a timeout is a statement about this pipeline on this machine under whatever load it had. The retention rule adopted after the first failure did not cover this one, because it was written about the object under study and what went unrecorded was the environment the study ran in. And a screen for this can only be applied forward, since arms already collected without host state cannot be re-screened, which is the same structural problem that withdrew the drift study appearing in a new variable. A postscript, because it took three attempts to see: two of those interruptions we attributed to memory pressure and treated with progressively better limits, a floor, then a strike counter, then an allowance for declared allocations, then marking the model server as the kernel's preferred OOM victim. All four were correct and none was the cause. The harness had started the server as a child process, so it ran inside the cgroup of the terminal that launched it and its memory was accounted to that scope; the kernel's log named the scope plainly and we did not read it until the third failure. Every fix chose which process the kernel would kill, and the defect was whose accounting it was killed inside.

Three objections remain that the work does not close, and they are stated rather than answered. The first is that the judge findings rest on four calls, because the intercept patches the reconciliation seam and the text-fallback builder and therefore requires a live judge call per observation. We concede the sample size and defend the design, which are different things. On the working path the finding is deductive rather than statistical, since the reconciliation step restores the cascade's set by construction and the 80-arm mechanism check confirms the bundle equals the cascade set on every arm, with the judge contributing one of its own on 0 of 8 samples, an upper bound of 0.375 on the per-sample rate. On the failing path it is an existence claim: uncorroborated identifiers do reach the analyst, demonstrated on four calls against an uncapped control whose raw text provably contains none. Neither claim is a rate, and what would settle it is the same intercept over the 97-sample cohort, which needs no new instrumentation, only the host. The second is that the detector's own evidence is retrospective: it found four defects on batches we already had reason to distrust, and the prospective test, reporting output cardinality beside every batch for a year and counting how many defects it catches before anything else does, is the experiment and we have not run it. The third is that seven defects in one's own code is a post-mortem rather than a result. We do not claim the category. Every mechanism was counter-searched in an adjacent field's vocabulary before being claimed and the search demoted more than it confirmed, so what we assert is narrower than a class: a setting where the artefact of such a failure is a measurement that is wrong and looks right, and a price paid rather than hypothesised.

All three were blocked by the same thing, a host on which the model server does not fit alongside anything else. Lifting an earlier objection shows what that takes: the blocker was never the method but that the server's resident set climbs with

cumulative requests and does not come back down, at 10.4 GB loaded and 18.1 GB after 60 minutes, unreclaimable, so a long run walks the host into its own memory guard. Cycling the server from the checkpoint between stretches of work turned a run that could not finish into one that did, which is a change to the method and not to the machine. That is what closed the objection that the equal-budget arms ran only on 5 synthesised fixtures whose evidence is in bijection with their answer key, a corpus on which a deterministic regular expression over the generating dictionary scores 1.000 on 5 of 5: two of the three arms were re-run on real binaries and the answer changed sign (Section 3.2). The frontier comparison and the confidence calibration still rest on that corpus and are reported as a pilot accordingly.

4. Conclusion

This work addressed two barriers to trusting a measurement of an LLM malware-analysis pipeline: that such pipelines are rarely scored against the deterministic tooling they are built on, and that the instrument producing the score is itself a distributed system whose failures do not announce themselves. We built a multi-agent pipeline mapping malware evidence to ATT&CK techniques and then spent longer measuring it than building it, at equal token budget against simpler alternatives, with a stochastic-noise control, with each mechanism’s firing rate measured before its effect, and with intervals resampled at the level the observations are independent at.

Conceptually, the contribution is a way of reading a component’s contribution that does not depend on the component working. A no-LLM baseline gives every F1 in the paper something to refer to; a firing rate decides in advance whether an ablation of a mechanism can say anything at all; a minimum detectable effect turns a null from an assertion of equivalence into a bound; and an output cardinality count, reported beside a batch result rather than run as a test, asks whether the instrument produced N answers or one answer N times. None of these is expensive and each of them changed a conclusion here.

Four architectural claims motivated the design and none survived measurement. Negotiated consensus does not beat a single judge at equal budget, the corroboration cascade never reaches the artefact the analyst receives, two-tier attribution fires too rarely to carry the result, and the confidence number every deterministic gate consumes is indistinguishable from chance. Where a corpus large enough to produce a significant answer was available, the finding is sharper than a null: the decomposition into several calls is worth +0.0537 F1 and the negotiation between them is worth nothing. None of those components is broken and each was built for a reason we would give again, but they do not move the end-to-end result, and we report that rather than a tuning opportunity. The finding we did not expect to be the paper is that the instrument was repeatedly wrong in ways that looked like data. Seven mechanisms are catalogued with the layer each occurred at; four crossed a boundary with another server, each returned a plausible result rather than an error, 2,744 passing tests caught none of them, and all four were found instead by one

arithmetic check on how many distinct outputs the inputs produced. Three crossed no boundary at all, and in each of those a measurement’s cause was assigned rather than measured.

We are careful about what is new. Silent failure at tool boundaries is documented, the metamorphic relation behind the detector is ordinary, the genus has a published taxonomy, and inference-time configuration inverting model rankings inside a constrained budget is established. What we add is the setting and the price. In an evaluation pipeline the artefact of such a failure is not a degraded user session but a measurement that is wrong and looks right, and the price here was concrete: one completed study withdrawn because its per-sample outputs were not retained and the question can no longer be asked of it, then four arms of a later ablation lost the same way one level up, because the rule written after the first failure was scoped to that failure and the environment a study runs in is also part of the instrument.

The limitations bound the reading directly. This is one pipeline, one 35B model at one quantisation, on one machine, evaluated on Windows PE malware against family-level ground truth, and most of its nulls are bounds set by a five-cluster corpus rather than equivalences. Future work follows from each: re-running the withdrawn temporal-drift study under the corrected instrument, extending the judge intercept from four calls to the full cohort, running the parameter-size series on endpoints that honour the reasoning flag so that scale and configuration can be separated, and testing the output-cardinality check prospectively rather than retrospectively by reporting it beside every batch and counting how often it is first to a defect. Each of those needs a host the model server does not fill on its own, which is the binding constraint on this work rather than the method.

What we do assert is a change of default. In a pipeline assembled from other people’s servers the correctness of the model is not the binding constraint on the correctness of the result. Long before a benchmark score is a claim about a system, it is a claim about an instrument, and a server that answers is not the same as a server that answered your question.

Declarations

Ethics, containment and data sources

Every sample analysed in this work is live Windows PE malware. The 97-sample cohort and the 210 dated samples of the withdrawn drift study were obtained from MalwareBazaar ([abuse.ch](https://bazaar.abuse.ch)), <https://bazaar.abuse.ch>, under terms that permit research redistribution of samples but not of the corpus as a package. MABEL, the Malware Analysis Benchmark for AI/ML, was mined offline into the family-fingerprint catalogue and the ATT&CK case corpus with no binaries downloaded; Ultimate-RAT-Collection supplied RAT builder and payload binaries for that catalogue and for the leakage-free retrieval split; DikeDataset was downloaded and assessed but not catalogued, its labels being coarse malice scores with no family or technique annotation. MITRE ATT&CK (Enterprise), <https://attack.mitre.org>, supplies the family-to-technique uses rela-

tionships used as per-sample ground truth, derived from mitre-attack/attack-stix-data under the ATT&CK Terms of Use.

Detonation happens only inside a CAPE sandbox on a dedicated Windows guest image reverted to a clean snapshot between analyses. The sandbox host is reachable from one network segment and from no public route, holds no credentials for any other system, and shares no filesystem with the host that runs the pipeline. Binaries are held only in a directory excluded from the host’s real-time scanner, are never committed to version control, and are not redistributed with this paper. We note a limitation of that arrangement rather than claiming it sufficient: the guest reaches the public internet during detonation, because a sample that cannot resolve its command-and-control infrastructure behaves differently from one that can and the network evidence channel would otherwise be empty for every sample. Live detonation with egress is the standard arrangement for behavioural sandboxing, and it is the arrangement whose consequences we report, including that most of the domains every sample contacted turn out to be the guest image describing itself. No user study was conducted, no personal data was collected, and no human analyst scored any output, that last point being a limitation of the evaluation rather than a claim about ethics.

Data availability and reproducibility

The evaluation harnesses, the derivation of every number in this paper, the per-sample records they read and the scripts that build the figures and assemble the document are released with the paper. The archive holds every per-sample record retained by every study reported here, in the JSON the harness wrote, together with the offline re-analysis that recomputes every interval, design effect, minimum detectable effect and adjusted p-value from those records and its random seed, the ATT&CK ground-truth fixtures, and the model digest and engine commit needed to reproduce the local arm. Every number this paper states about its own results is generated from those records into a macro and referenced rather than typed, and a key the document asks for that the derivation cannot produce stops the build. Two runs of the offline analysis produce byte-identical output, asserted by a test in the released suite rather than claimed here, and every interval carries the seed, the iteration count and the number of clusters it was computed from. The live arms are not bit-reproducible and we do not claim they are: decoding is at temperature 0.1 on the local arm and at each provider’s default on the hosted ones, one of which accepts a reasoning-configuration parameter and does not act on it, so anyone re-running them should expect the numbers to move and should read the intervals accordingly.

Four things are withheld. Malware binaries are not released and are obtainable from the sources named above by the SHA-256 digests in the archive. Sandbox reports are not released in full because they embed strings and memory contents from the samples. The sandbox host’s address appears nowhere in the archive. And one dataset used for retrieval-corpus construction is redistributed by its authors under terms that do not permit our redistribution, so it is referenced rather than included. One thing is not available at all: the 210-sample temporal-drift study’s per-sample

outputs do not exist, having been written to a path that was valid on the machine the harness was first written on and silently relative on the machine it ran on. The study is withdrawn on that account and the withdrawal is reported in the results rather than quietly repaired. The manifest of the 210 samples survives and is included, so the cohort can be reconstructed even though the results cannot.

Use of generative AI

Large language models are the object of study in this work, so the pipeline under evaluation is built from them and every measurement reported here is a measurement of their behaviour in it. Separately, generative AI was used as an authoring and engineering aid, for drafting and revising prose, writing evaluation harnesses and their tests, and performing literature searches whose results were then verified by fetching each source. That verification is not incidental to this disclosure: of the nine citations added by those searches and checked one by one, three said something the source did not, one quoted a sentence absent from the paper, one cited a practice the source does not describe, and one blended two incompatible published accounts into a single attribution. All are corrected in the text and the corrections are recorded, because a search summary that reads as a citation is the same class of failure this paper is about. An internal readability assessment of report narratives was performed with a language model as a development aid; its results are deliberately excluded and no LLM scored any result reported here. The authors take responsibility for all content, including every number, every citation, and every claim about what the measurements support.

Competing interests

The authors declare no competing financial or non-financial interests. No external funding supported this work. All measurements were taken on hardware owned by the authors, except for calls to three commercially hosted inference endpoints, which were paid for at their public list prices and whose providers had no involvement in, or advance knowledge of, this evaluation.

References

- [1] M. Büchel, T. Paladini, S. Longari, M. Carminati, S. Zanero, et al., SoK: Automated TTP extraction from CTI reports, are we there yet?, in: 34th USENIX Security Symposium, 2025, pp. 4621–4641.
- [2] H. S. Gunawi, C. Rubio-González, A. C. Arpaci-Dusseau, R. H. Arpaci-Dusseau, B. Liblit, EIO: Error handling is occasionally correct, in: 6th USENIX Conference on File and Storage Technologies (FAST), 2008, measures error loss at module boundaries: 1153 of 9022 propagation channels (13%) drop an error code without handling it, and inter-module calls are a major cause.

- [3] D. Yuan, Y. Luo, X. Zhuang, G. R. Rodrigues, X. Zhao, Y. Zhang, P. U. Jain, M. Stumm, Simple testing can prevent most critical failures: An analysis of production failures in distributed data-intensive systems, in: 11th USENIX Symposium on Operating Systems Design and Implementation (OSDI), 2014, an error handler that only logs the error is counted as ignoring it; 25% of catastrophic failures arise that way, and 92% from incorrect handling of errors that were explicitly signalled.
- [4] A. Alquraan, H. Takruri, M. Alfatafta, S. Al-Kiswany, An analysis of network-partitioning failures in cloud systems, in: 13th USENIX Symposium on Operating Systems Design and Implementation (OSDI), 2018, pp. 51–68, “The majority of the failures were silent”, and where a warning was returned “all returned warnings were confusing, with no clear mechanism for resolution”.
- [5] J. Xue, Y. Zhao, Y. Wang, J. Chen, D. Wang, A characterization study of bugs in LLM agent workflow orchestration frameworks, in: 40th IEEE/ACM International Conference on Automated Software Engineering (ASE), Industry Showcase, 2025, pp. 3369–3380, 1026 bugs across LangChain, LlamaIndex and Haystack; nine root causes and six symptom categories. doi:10.1109/ASE63991.2025.00278.
- [6] M. Liu, S. Zhong, W. Bi, Y. Zhang, Z. Chen, Z. Chen, X. Liu, Y. Ma, A first look at bugs in LLM inference engines, ACM Transactions on Software Engineering and Methodology 929 bugs across llama.cpp, vLLM and four other engines; the taxonomy carries both “Incorrect Request Parsing” as a root cause and “Silent Error” as a symptom (2026). doi:10.1145/3788873.
- [7] W. Yu, et al., Maltracker: A fine-grained NPM malware tracker copiloted by LLM-enhanced dataset, in: Proceedings of the 33rd ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA), 2024. doi:10.1145/3650212.3680397.
- [8] W. Zhao, et al., AppPoet: LLM-based Android malware detection via multi-view prompt engineering, Expert Systems with Applications 262, arXiv:2404.18816 (2025).
- [9] A. Rollinson, N. Polatidis, LLM-generated samples for Android malware detection, Digital 6 (1) (2026) 5. doi:10.3390/digital6010005.
- [10] S. Saha, et al., MaLAware: Automating the comprehension of malicious software behaviours using LLMs, in: IEEE/ACM International Conference on Mining Software Repositories (MSR), 2025, arXiv:2504.01145.
- [11] Center for Threat-Informed Defense, TRAM: Threat report ATT&CK mapper, Open-source software, MITRE Engenuity, not a paper and cited as the artefact it is; the repository names no preferred citation (2023).

- [12] V. Legoy, M. Caselli, C. Seifert, A. Peter, Automated retrieval of ATT&CK tactics and techniques for cyber threat reports, in: 1st Cyber Threat Intelligence Symposium (CTI), 2020, arXiv:2004.14322. Recorded as a conference contribution by the University of Twente research portal; not indexed under this title in dblp.
- [13] G. Husari, E. Al-Shaer, M. Ahmed, B. Chu, X. Niu, TTPDrill: Automatic and accurate extraction of threat actions from unstructured text of CTI sources, in: Proceedings of the 33rd Annual Computer Security Applications Conference (ACSAC), 2017, pp. 103–115. doi:10.1145/3134600.3134646.
- [14] K. Satvat, R. Gjomemo, V. N. Venkatakrishnan, EXTRACTOR: Extracting attack behavior from threat reports, in: IEEE European Symposium on Security and Privacy (EuroS&P), 2021, pp. 598–615.
- [15] Z. Li, J. Zeng, Y. Chen, Z. Liang, AttacKG: Constructing technique knowledge graph from cyber threat intelligence reports, in: Computer Security, ESORICS, 2022, pp. 589–609. doi:10.1007/978-3-031-17140-6_29.
- [16] M. T. Alam, D. Bhusal, Y. Park, N. Rastogi, Looking beyond IoCs: Automatically extracting attack patterns from external CTI, in: 26th International Symposium on Research in Attacks, Intrusions and Defenses (RAID), 2023, pp. 92–108, the LADDER framework.
- [17] A. Lekssays, U. Shukla, H. T. Sencar, M. Parvez, TechniqueRAG: Retrieval augmented generation for adversarial technique annotation in CTI text, in: Findings of the Association for Computational Linguistics (ACL), 2025, arXiv:2505.11988.
- [18] F. Morbiato, M. Keller, P. Nair, L. Romano, Hierarchical retrieval augmented generation for adversarial technique annotation in cyber threat intelligence text, PREPRINT, not peer reviewed. arXiv:2604.14166 (2026).
- [19] Y. Cheng, C. Li, R. S. P. Basuki, Q. Cui, W. Ding, P. Gao, TTPrint: Evidence-grounded TTP extraction via diverge-then-converge verification, PREPRINT, not peer reviewed. arXiv:2605.25836; the Comments field says so in as many words. Kept because its evidence-grounding requirement is the design constraint our own gate obeys, so dropping it would let us appear to have set that bar ourselves (2026).
- [20] K. D’Oosterlinck, O. Khattab, F. Remy, T. Demeester, C. Develder, C. Potts, In-context learning for extreme multi-label classification, PREPRINT, not peer reviewed. arXiv:2401.12178, v1 only, no Comments and no journal reference (2024).
- [21] L. Lange, H. Adel, et al., AnnoCTR: A dataset for detecting and linking entities, tactics, and techniques in cyber threat reports, in: Joint International

Conference on Computational Linguistics, Language Resources and Evaluation (LREC-COLING), 2024, arXiv:2404.07765. CC-BY-SA 4.0.

- [22] A. Abdallah, J. Holdcroft, M. Ali, A. Jatowt, Are LLM-based retrievers worth their cost? an empirical study of efficiency, robustness, and reasoning overhead, in: Proceedings of the 49th International ACM SIGIR Conference on Research and Development in Information Retrieval, 2026, arXiv:2604.03676.
- [23] H. T. Ng, et al., The CoNLL-2014 shared task on grammatical error correction, in: Proceedings of the Eighteenth Conference on Computational Natural Language Learning: Shared Task, 2014, cited with the BEA-2019 shared task for the $F_{0.5}$ convention, which weights precision twice recall to penalise over-correction. The convention is documented by the shared tasks themselves.
- [24] C. Bryant, M. Felice, Ø. E. Andersen, T. Briscoe, The BEA-2019 shared task on grammatical error correction, in: Proceedings of the Fourteenth Workshop on Innovative Use of NLP for Building Educational Applications, 2019.
- [25] S. Welleck, I. Kulikov, S. Roller, E. Dinan, K. Cho, J. Weston, Neural text generation with unlikelihood training, in: International Conference on Learning Representations (ICLR), 2020, arXiv:1908.04319. Welleck et al. blame the likelihood objective itself; the training-data account is the other paper’s.
- [26] H. Li, T. Lan, Z. Fu, D. Cai, L. Liu, N. Collier, T. Watanabe, Y. Su, Repetition in repetition out: Towards understanding neural text degeneration from the data perspective, in: Advances in Neural Information Processing Systems (NeurIPS), 2023, arXiv:2310.10226. Argues that self-reinforcement explanations reduce to the training-data account.
- [27] G. Chen, H. Sun, D. Liu, Z. Wang, Q. Wang, B. Yin, L. Liu, L. Ying, Re-Copilot: Reverse engineering copilot in binary analysis, PREPRINT, not peer reviewed. arXiv:2505.16366, v1 only, no Comments and no journal reference. Cited only as one of the open-weight binary specialists that establish the model-tier split (2025).
- [28] H. Tan, Q. Luo, J. Li, Y. Zhang, LLM4Decompile: Decompile binary code with large language models, in: Proceedings of the 2024 Conference on Empirical Methods in Natural Language Processing (EMNLP), 2024, pp. 3473–3487. doi:10.18653/v1/2024.emnlp-main.203.
- [29] N. Jiang, C. Wang, K. Liu, X. Xu, L. Tan, X. Zhang, P. Babkin, Nova: Generative language models for assembly code with hierarchical attention and contrastive learning, in: International Conference on Learning Representations (ICLR), 2025, poster. arXiv:2311.13721.
- [30] Z. Xuan, X. Xu, M. Zheng, L. Z.-H. Tan, J. Guo, T. Zhang, L. Yu, C. Wang, X. Zhang, Identifying adversary tactics and techniques in malware binaries with an LLM agent, PREPRINT, not peer reviewed. TTPDetect.

arXiv:2602.06325. Kept because it is the nearest system to ours and the sentence citing it concedes ground rather than claims it; dropping it for want of a venue would let this paper imply it holds that ground itself. No peer-reviewed system with the same scope was found (2026).

- [31] K. Kate, T. Pedapati, K. Basu, Y. Rizk, V. Chenthamarakshan, S. Chaudhury, M. Agarwal, I. Abdelaziz, LongFuncEval: Measuring the effectiveness of long context models for function calling, PREPRINT, not peer reviewed. arXiv:2505.10570, v1 only, no Comments and no journal reference. Kept because it says the tool-catalogue degradation we report is already documented in general, which is the direction that costs us (2025).
- [32] V. Paramanayakam, A. Karatzas, I. Anagnostopoulos, D. Stamoulis, Less is more: Optimizing function calling for LLM execution on edge devices, in: Design, Automation and Test in Europe Conference (DATE), 2025, arXiv:2411.15399. Both quoted figures were confirmed against the full text.
- [33] W. Li, S. Manickam, Y.-w. Chong, S. Karuppayah, PhishDebate: An LLM-based multi-agent framework for phishing website detection, in: IEEE International Conference on Big Data (BigData), 2025, pp. 6606–6615, arXiv:2506.15656. The published citation is given in the arXiv Comments field. doi:10.1109/BigData66926.2025.11401440.
- [34] D. Tran, D. Kiela, Single-agent LLMs outperform multi-agent systems on multi-hop reasoning under equal thinking token budgets, PREPRINT, not peer reviewed. arXiv:2604.02460. Kept because it says our null is not the first of its kind, and because the crossover figure it reports for our own model class has no reviewed equivalent we could verify. Bertalanič and Fortuna reach the same conclusion in a reviewed venue (2026).
- [35] B. Bertalanič, C. Fortuna, The cost of consensus: Isolated self-correction prevails over unguided homogeneous multi-agent debate, in: ACM Conference on AI and Agentic Systems, 2026, arXiv:2605.00914. doi:10.1145/3786335.3813137.
- [36] D. Lea, J. Ghawaly, G. G. Richard III, A. Ali-Gombe, A. Case, REx86: A local large language model for assisting in x86 assembly reverse engineering, in: Annual Computer Security Applications Conference (ACSAC), 2025, arXiv:2510.20975.
- [37] R. Evertz, N. Risse, C. Neuer, N. Müller, S. Normann, et al., Chasing shadows: Pitfalls in LLM security research, in: Network and Distributed System Security Symposium (NDSS), 2026, arXiv:2512.09549. Living appendix at llmpitfalls.org.
- [38] J. Ng, A. Milani Fard, Evaluating retrieval-augmented generation for explainable malware analysis, in: ACM SecDev, 2026, poster. arXiv:2605.03140.

- [39] J. Metz, L. F. D. de Abreu, E. A. Cherman, M. C. Monard, On the estimation of predictive evaluation measure baselines for multi-label learning, in: *Advances in Artificial Intelligence, IBERAMIA, Lecture Notes in Computer Science*, 2012, pp. 189–198, crossref types LNCS proceedings as book-chapter by convention; the container title is the IBERAMIA 2012 proceedings. doi:10.1007/978-3-642-34654-5_20.
- [40] J. Metz, N. Spolaôr, E. A. Cherman, M. C. Monard, Comparing published multi-label classifier performance measures to the ones obtained by a simple multi-label baseline classifier, PREPRINT, not peer reviewed. arXiv:1503.06952, v1 only, no venue. Kept for its systematic-review finding rather than for the requirement itself, which now rests on the reviewed IBERAMIA 2012 paper by the same group (2015).
- [41] A. Lazaridou, A. Kuncoro, E. Gribovskaya, et al., Mind the gap: Assessing temporal generalization in neural language models, in: *Advances in Neural Information Processing Systems (NeurIPS)*, 2021, arXiv:2102.01951.
- [42] T. Xu, J. Zhang, P. Huang, J. Zheng, T. Sheng, D. Yuan, Y. Zhou, S. Pasupathy, Do not blame users for misconfigurations, in: *24th ACM Symposium on Operating Systems Principles (SOSP)*, 2013, pp. 244–259, names the failure mode: “silent overruling refers to the case that the system changes an unacceptable user setting into the default value without notifying the user”, measured across 74 parameters in Squid and Apache. doi:10.1145/2517349.2522727.
- [43] O. Oyelayo, S. Abedu, S. Khatoonabadi, E. Shihab, Developer challenges in the adoption of model context protocol in AI agent development, in: *7th International Workshop on Bots and Agents in Software Engineering (BotSE)*, co-located with ICSE, 2026, pp. 53–59, bug reports and pull requests on MCP reference servers: data validation and type issues are the second most prevalent class at 13.97%. doi:10.1145/3786161.3788462.
- [44] A. Martin-Lopez, S. Segura, A. Ruiz-Cortés, A catalogue of inter-parameter dependencies in RESTful web APIs, in: *Service-Oriented Computing (IC-SOC)*, 2019, pp. 399–414, across 40 APIs and over 2500 operations, input dependencies are “the norm, rather than the exception, with 85% of the reviewed APIs” having them, and OpenAPI cannot express them. doi:10.1007/978-3-030-33702-5_31.
- [45] Y. Li, Z. Liu, P.-L. Poon, D. Towey, C.-A. Sun, et al., Metamorphic relation generation: State of the art and research directions, *ACM Transactions on Software Engineering and Methodology* Preprint arXiv:2406.05397 (2024). doi:10.1145/3708521.
- [46] S. Dev, A. Sloan, J. Kavner, N. Kong, M. Sandler, Judge reliability harness: Stress testing the reliability of LLM judges, in: *Agents in the Wild: Safety,*

Security, and Beyond Workshop, International Conference on Learning Representations (ICLR), 2026, arXiv:2603.05399. Corrected: this paper does not establish the duplicate-item practice an earlier draft cited it for; it perturbs formatting, paraphrase, verbosity and labels.

- [47] A. Ryan, S. S. Noor, M. Erfan, S. Mitra, S. Mittal, M. R. Rahman, Evaluating open-source LLMs for multi-label ATT&CK technique classification on CTI reports, PREPRINT, not peer reviewed. arXiv:2606.18166. The quoted correlation is from the full text, not the abstract: “the Spearman rank correlation confirms a statistically significant relationship between parameter size and F_1 scores in this CTI classification task ($\rho=0.85$, $p=0.014$)” (2026).
- [48] Y. Sun, H. Wang, J. Li, J. Liu, X. Li, H. Wen, Y. Yuan, H. Zheng, Y. Liang, Y. Li, Y. Liu, An empirical study of LLM reasoning ability under strict output length constraint, in: Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing, 2025, pp. 7652–7671, finding 3: under strict output constraints reasoning performance “might not scale monotonically with the model size”. Finding 4 independently covers our reasoning-flag confound: reasoning models do not always outperform instruction-tuned ones under the same constraint. doi:10.18653/v1/2025.emnlp-main.389.
- [49] M. Mizrahi, G. Kaplan, D. Malkin, R. Dror, D. Shahaf, G. Stanovsky, State of what art? A call for multi-prompt LLM evaluation, Transactions of the Association for Computational Linguistics 12 (2024) 933–949, 6.5M instances over 20 models and 39 tasks: “different instruction templates lead to very different performance, both absolute and relative”, and the relative part is the ranking. doi:10.1162/tac1_a_00681.
- [50] C. Snell, J. Lee, K. Xu, A. Kumar, Scaling LLM test-time compute optimally can be more effective than scaling parameters for reasoning, in: International Conference on Learning Representations (ICLR), 2025, oral. “In a FLOPs-matched evaluation, we find that on problems where a smaller base model attains somewhat non-trivial success rates, test-time compute can be used to outperform a 14x larger model”.
- [51] M. Hassid, T. Remez, J. Gehring, R. Schwartz, Y. Adi, The larger the better? Improved LLM code-generation via budget reallocation, in: First Conference on Language Modeling (COLM), 2024, the ranking flips and flips back on an inference-time choice alone: repeated small-model sampling gains up to 15% with a unit-test oracle, and loses to a single large-model output without one.
- [52] M. Jin, Q. Yu, D. Shu, H. Zhao, W. Hua, Y. Meng, Y. Zhang, M. Du, The impact of reasoning step length on large language models, in: Findings of the Association for Computational Linguistics: ACL, 2024, pp. 1830–1842, cited as the counterweight: lengthening reasoning steps “considerably enhances

LLMs' reasoning abilities". Read with Sun et al., the effect is task- and budget-dependent rather than monotone in either direction. doi : 10.18653/v1/2024.findings-acl.108.

- [53] max_tokens not respected on the non-chat endpoint, PREPRINT, not peer reviewed. ggml-org/llama.cpp issue #8634. Search result; the issue has not been read in full. Cited with the vllm issue to demote our own mechanism to a known integration wart, which is the conservative direction (2024).
- [54] Request for a server-side output cap, PREPRINT, not peer reviewed. vllm-project/vllm issue #11976 (2024).